

Chapter 1

Introduction to Cryptography and Data Security



CyberSecurity Malaysia report: Government sectors suffered most data breaches, while telcos spilled over 400GB of data in H1 2023

By ANGELIN YEOH



CYBERSECURITY

Wednesday, 25 Oct 2023

4:26 PM MYT



February recorded the highest number of incidents, totalling 197, involving nine government and nine private entities. - 123rf.com

PETALING JAYA: According to the CyberSecurity Malaysia report, the government sector experienced the greatest number of data breaches, while the telecommunications sector leaked the highest volume of data in the first half of the year.



Telekom Malaysia (TM) has confirmed a recent data breach involving historical Unifi customers' personal information that includes name, national identification, passport number and contact details.

KUALA LUMPUR: Telekom Malaysia (TM) has confirmed a recent data breach involving historical Unifi customers' personal information that includes name, national identification, passport number and contact details.

In a statement today, the company said no financial information was affected.

"The company confirms that the breach has been contained and proactive steps have been taken to protect the data across its platforms.

"It has sent out notifications to customers informing them of the data breach and to be wary of phishing tactics including online scams, suspicious links and unsolicited phone calls," it said in a statement today.



PART 1: **DATA SECURITY**

Outlines

1. Security goals.
2. Security attacks.
3. Security services and mechanisms.

Learning Objectives

In the end of this Part 1, students should be able:

1. To define the **three security goals**.
2. To define the **security attacks** that threaten the security goals.
3. To define the **security services** and how they are related to the three security goals.
4. To define the **security mechanisms** to provide the security goals.

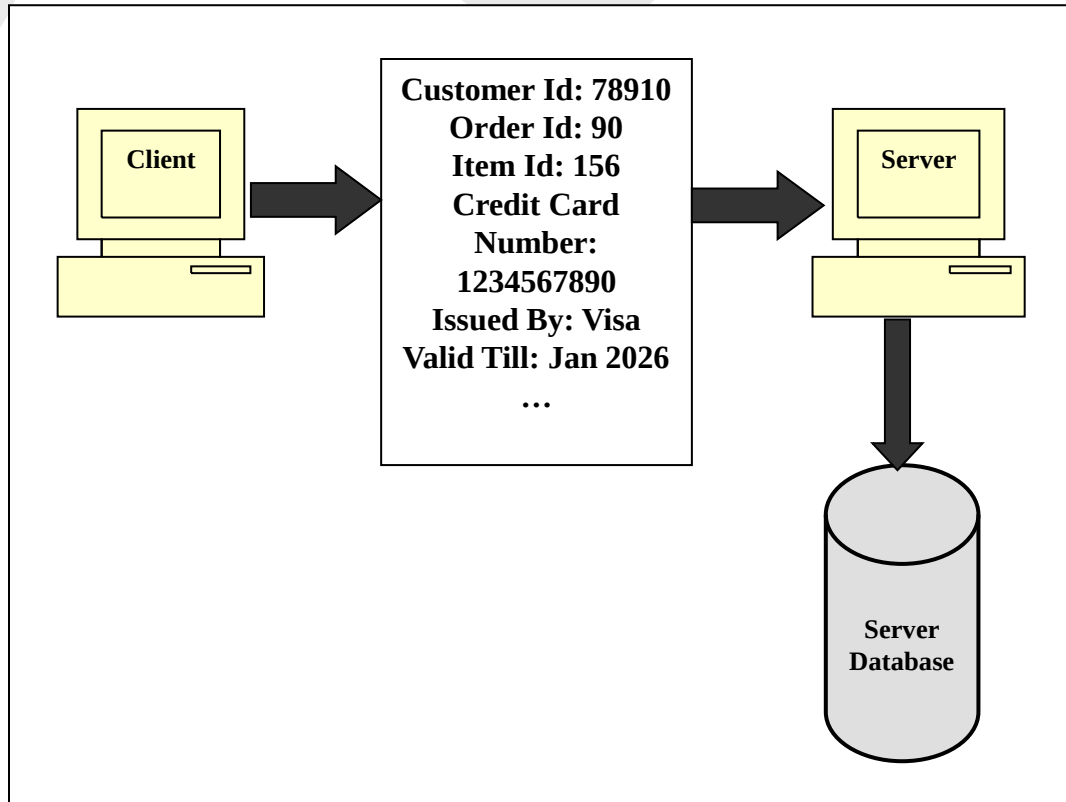


SECURITY GOALS

Need for Information Security

- Information Security requirements have changed in recent times.
- Traditionally, they are provided by **physical** and **administrative mechanisms**.
- Computer user requires automated tools to **protect** files and other stored information.
- Use of networks and communications links requires measures to protect data during transmission.

Need for Information Security



Example:

❖ Possible security holes:

- Intruder capture the details as they travel.
- Attacker gain access to the merchant database.

❖ Event Happened:

- An attacker intrude into a merchant database and obtained credit card numbers and released/sold some of the card numbers on the internet.
- Consequences: Financial loss, and loss of goodwill.

Need for Information Security

❖ Privacy concerns:

- Collecting info about people and misusing it
 - **Data mining techniques** - to process and tabulate the needed details about individuals Illegally sell the info.

❖ No concern about the distance:

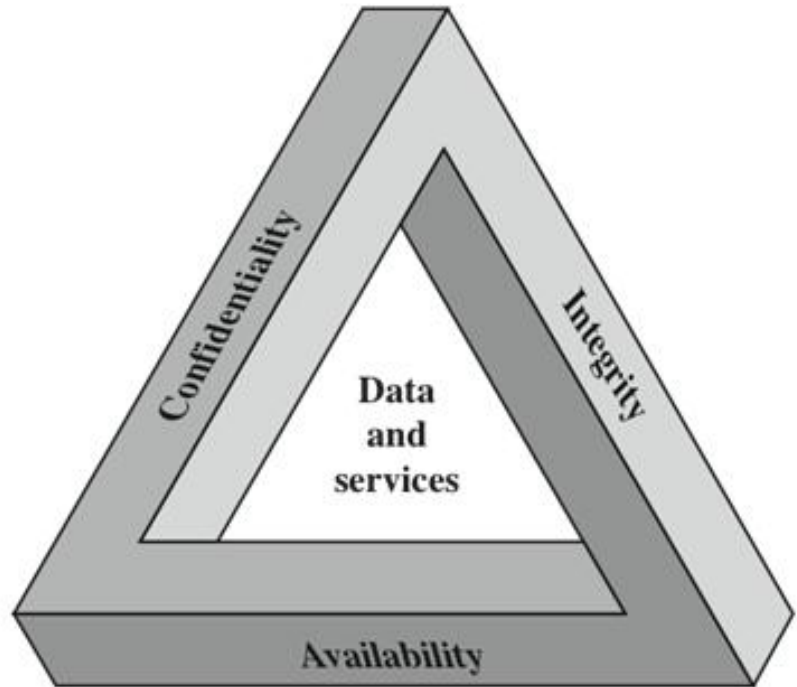
- Remote breaking of bank servers.
- Remote stealing credit card/ATM info.

Security Concepts

❖ What is Security?

- Taking measures that **prevent** assets from being damaged.
 - Taking measures to **detect** when, how and by whom an asset has been damaged.
 - Taking measures so that you can **recover** from a damage to assets.
- ❖ Security refers to the act of taking measures to facilitate **Prevention**, **Detection** and **Recovery** of assets from being damaged.

Security Goals - The CIA Triad



The **CIA** Triad:

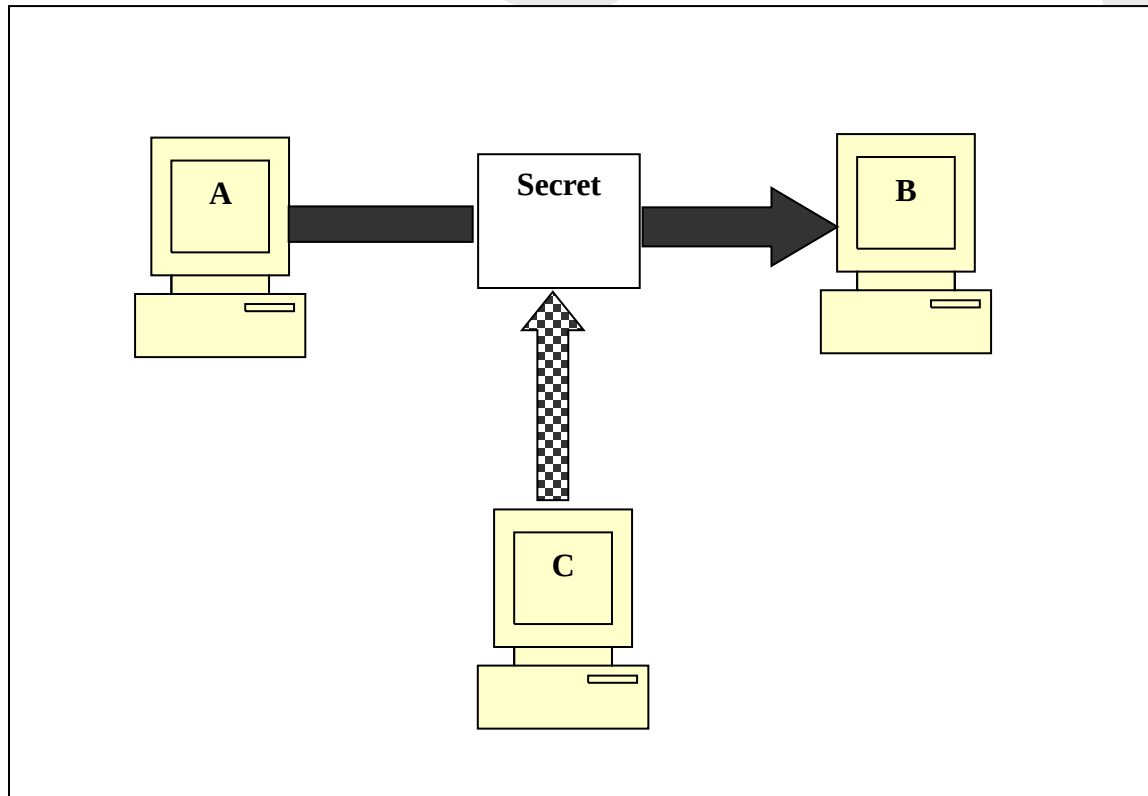
- C - **Confidentiality**
- I - **Integrity**
- A - **Availability**

Please be reminded **NOT** to confuse **Availability** with **Authentication**.

The CIA Triad – Confidentiality

- ❑ The assurance of the **secrecy** of the transmitted information, such that the content is readable/accessible only by both the intended sender and receivers
- ❑ The transmitted data should be protected from **passive attacks**:
 - ❖ **Snooping:**
 - Unauthorized access to / interception of the transmitted data over insecure communication channel.
 - ❖ **Traffic analysis:**
 - Observation over the source, destination, frequency, length or other characteristics of the traffic on a communication facility by an attacker to guess the nature of the transmission.

The CIA Triad – Confidentiality



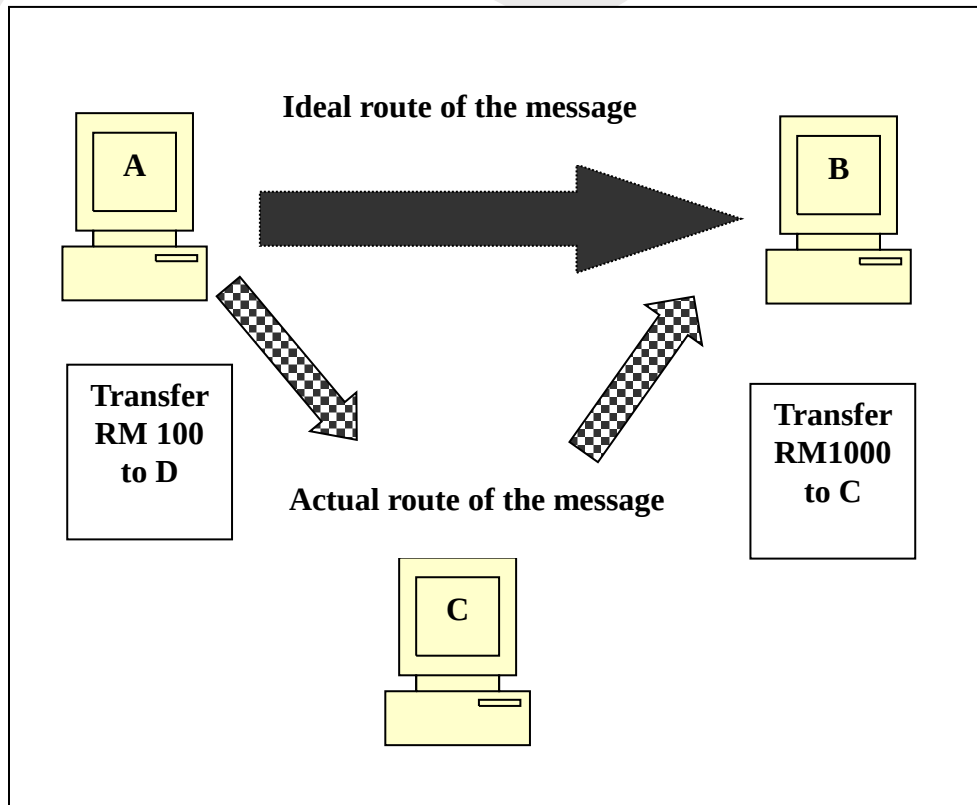
Example:

- Confidential email message sent by A to B, but accessed by C without the permission or knowledge of A and B.
- **Type of attack - Interception**
 - Interception causes loss of message (hence violates the confidentiality)

The CIA Triad – Integrity

- ❑ The assurance that data received are **the same** as sent by an authorized entity.
- ❑ The message from the sender to the receiver must travel without any alterations
- ❑ Any changes to a message / transmitted data are detectable and verifiable by the entities.
- ❑ The transmitted data should be protected from **active attacks**:
 - ❖ **Modification** - The data is modified / changed by an attacker for its benefits.
 - ❖ **Masquerading** - An entity is impersonated by an attacker.
 - ❖ **Replaying** - Obtain of the same message / data sent and replayed for its benefits.
 - ❖ **Repudiation** - The denial of entity (sender or receiver) that sent or received the message.

The CIA Triad – Integrity



Example:

- User C tampers with an original message sent by user A to B. User C access and change its contents and relay it to B.
- However, both users B and A have no idea about the changes done.
- **Type of attack: Modification**
 - Modification causes loss of message integrity.

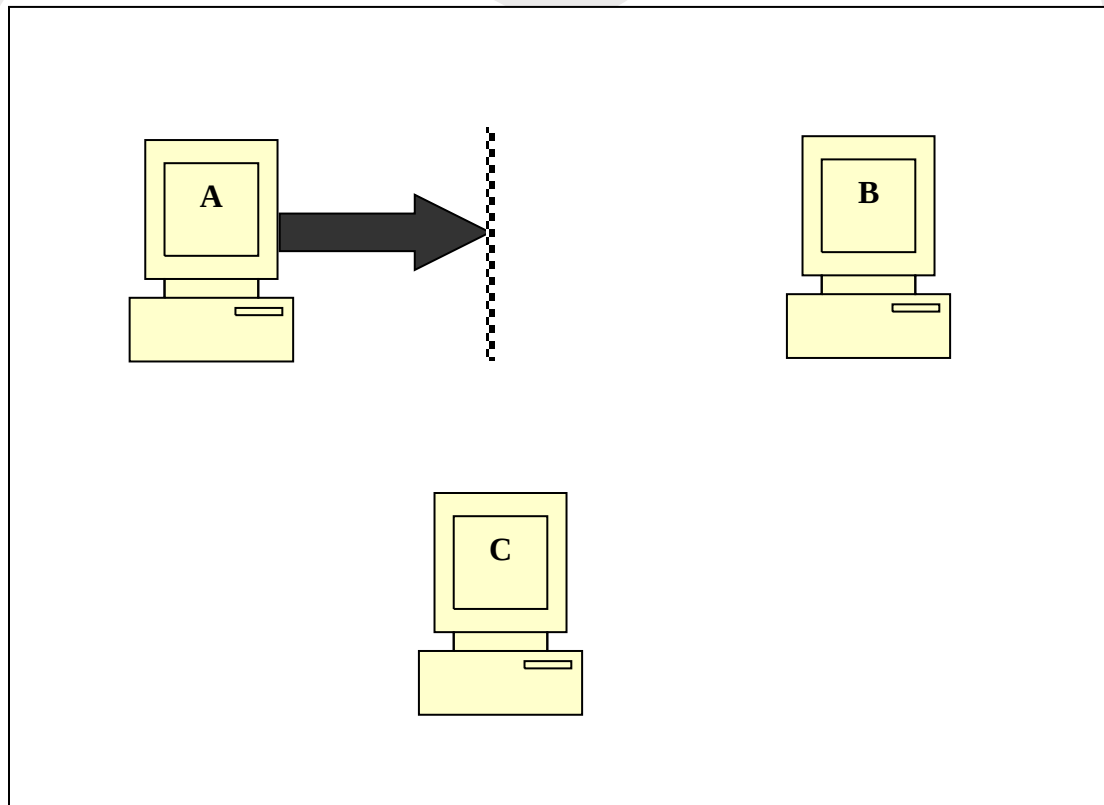
The CIA Triad – Availability

- ❑ The assurance of the resources / applications that must be available to authentic users all the time.
- ❑ It depends on the proper management and control of system resources, as well as the access control service and other security services.
- ❑ The availability of the data should be protected from **active attacks**:

❖ Denial of Service (DoS)

- The slow down or interruption of the service of a system, where an attacker may send many bogus requests to cause the server to crash, making the user / client believe that the server is not responding.
- The interception of requests made by the client, causing the client to send repetitive requests to overload the system.

The CIA Triad – Availability



Example:

- Due to intentional actions of an unauthorized user C, an authorized user A may not be able to contact a server computer B
- **Type of attack: Interruption**
 - Interruption puts the availability of resources in danger.



SECURITY THREATS / ATTACKS

OSI Security Architecture

- ❑ **ITU-T** (International Telecommunication Union - Telecommunication Standardization Sector) Recommendation X.800 "Security Architecture for OSI":
 - Defines a systematic way of defining and providing security requirements and characterizing the approaches to satisfy the requirements.
 - Useful to the managers as a way of organizing the task of providing security .
 - Computer and communication vendors develop security features for their products and services based on this.
 - Information security is about how to prevent attacks, or failing that, to detect attacks on information-based systems
 - Focuses on 3 aspects of information security: **Security attack**, **Security service**, and **Security mechanism**.

OSI Security Architecture

1. Security Attack

- Any action that compromises the security of information owned by an organization.

2. Security Service

- A processing or communication service that enhances the security of the data processing systems and information transfers of an organization.
- To counter security attacks, and may use one or more security mechanisms.

3. Security Mechanism

- A process or a device incorporating such a process that is designed to detect, prevent, or recover from a security attack.

OSI Security Architecture

❖ **Definitions** (RFC 2828, Internet Security Glossary):

1. **Threat:**

- A potential for violation of security, which exists when there is a circumstance, capability, action, or event that could breach security and cause harm.
- A threat is a possible danger that might exploit a vulnerability.

2. **Attack:**

- An assault on system security that derives from an intelligent threat.
- An intelligent act that is a deliberate attempt to evade security services and violate the security policy of a system.

- ❖ The terms **threat** and **attack** are commonly used to mean the same thing in the literature.

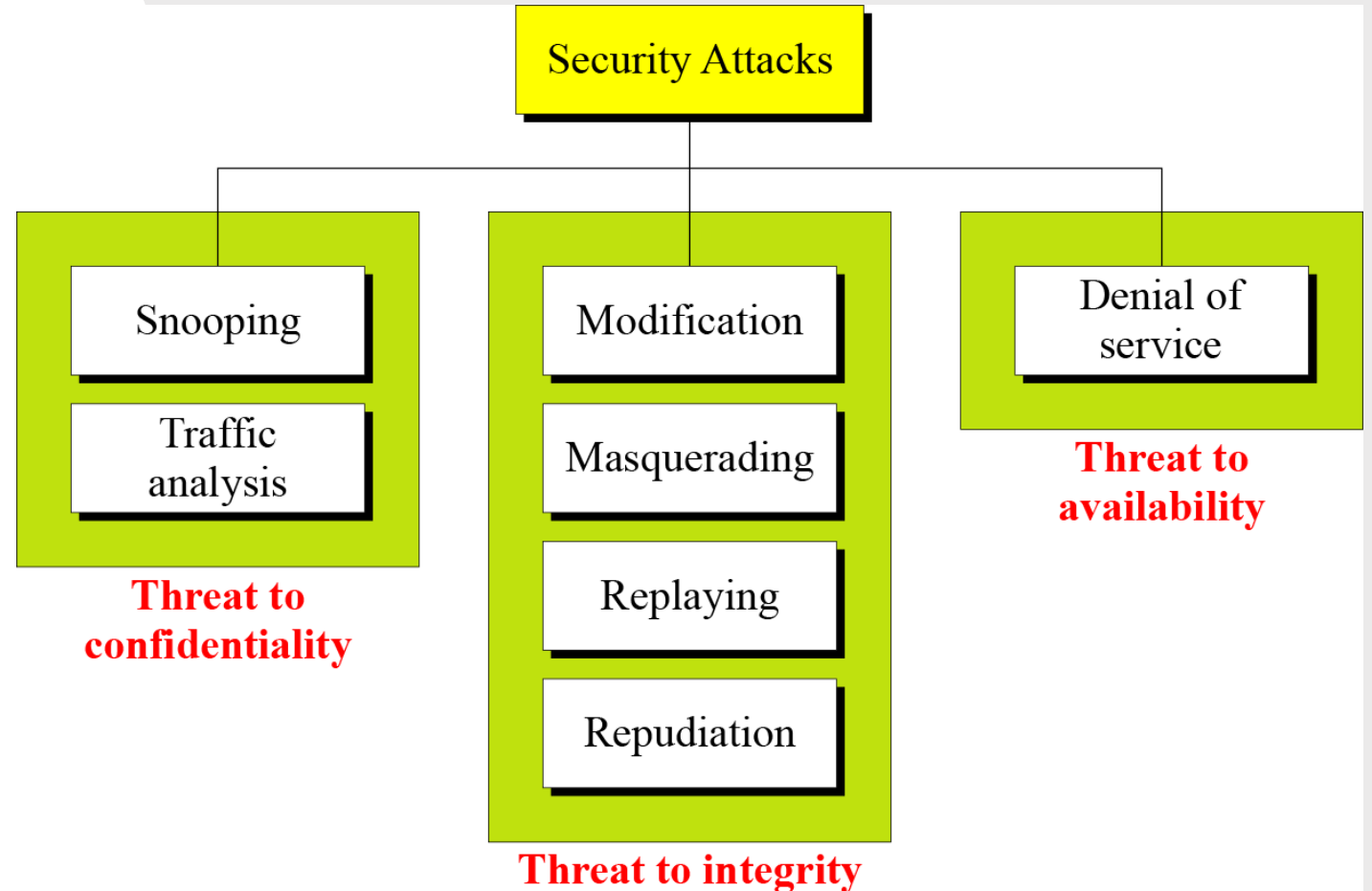
Security Threats / Attacks

❑ General classification according to theoretical concepts behind attacks:

1. **Interruption:** Asset of system becomes lost/unavailable that puts the **availability** of resources in danger.
2. **Interception:** Unauthorized access to an asset of the system that causes loss of message **confidentiality**.
3. **Modification:** Tampering the asset of the system by unauthorized party which causes loss of message **integrity**.
4. **Fabrication:** Skillful modifications of the system that could be indistinguishable from real thing which is possible in absence of proper **authentication** mechanisms.

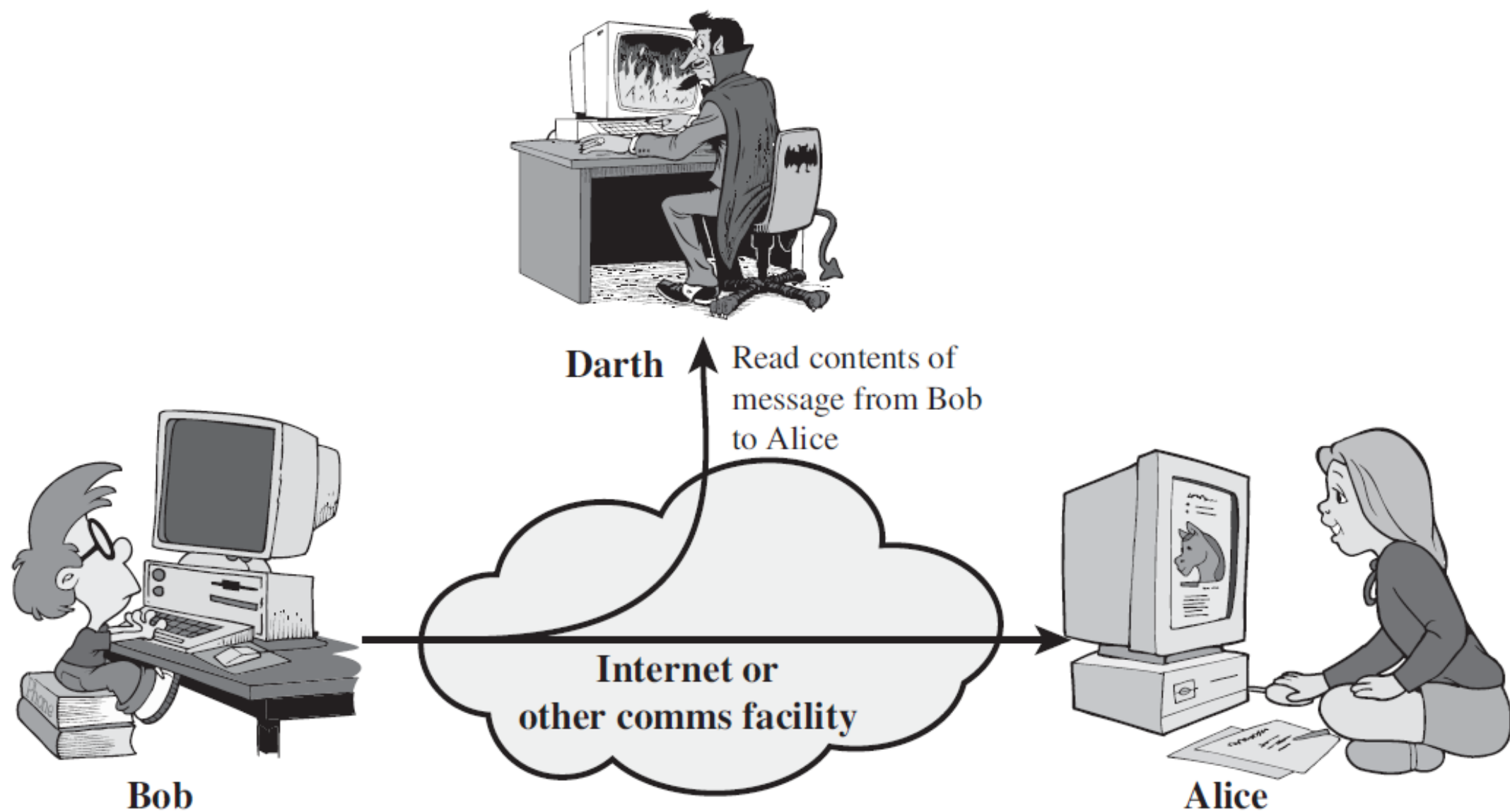
Security Threats / Attacks

- ❑ Taxonomy of attacks with relation to security goals. (Left diagram).
- ❑ The attacks can also be classified according to practical approach used by attackers:
 - **Passive Attacks**
 - **Active Attacks**

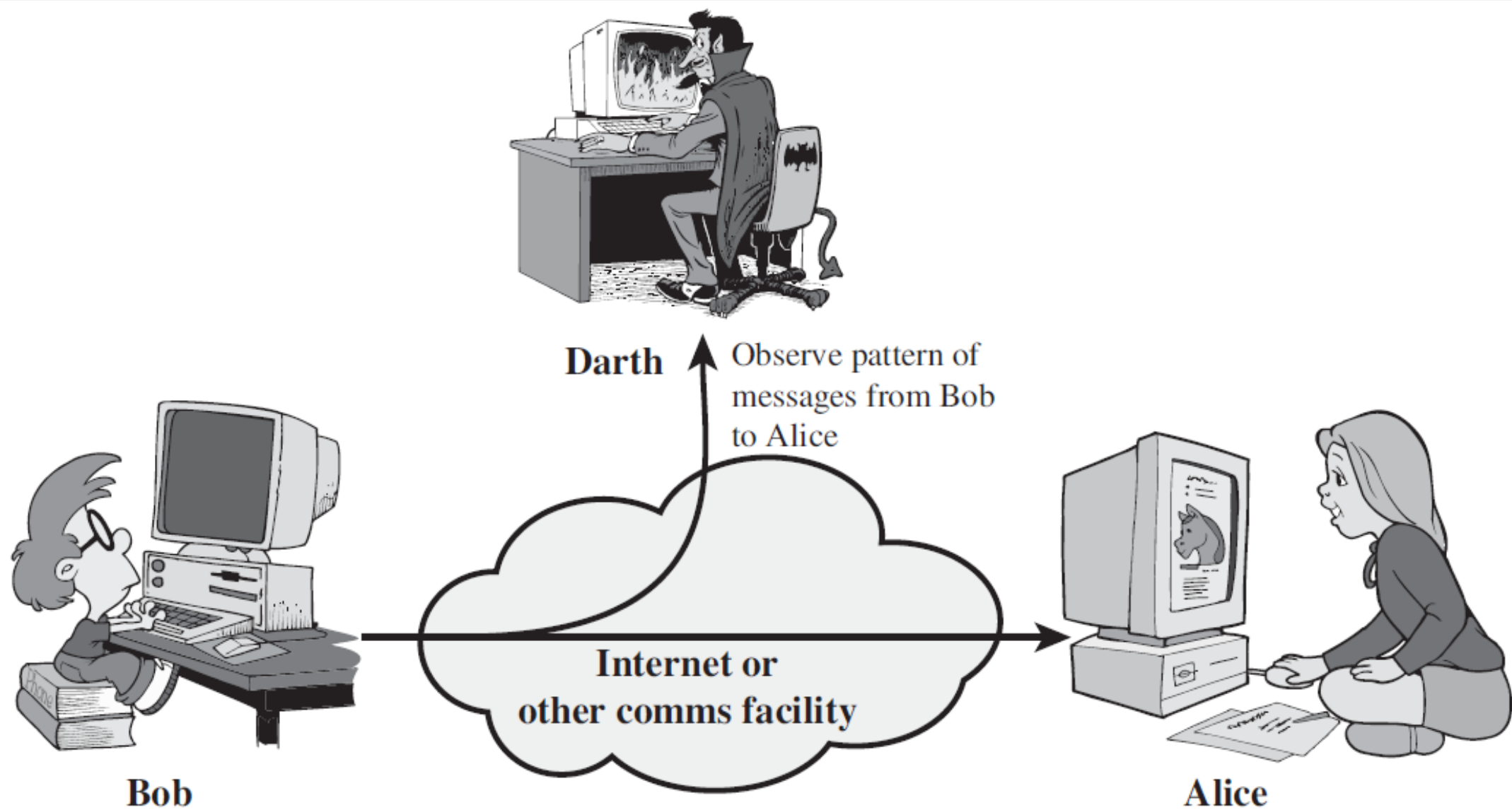


Security Threats / Attacks – Passive Attacks

- ❖ Passive attacks **do not involve any modifications to the contents** of an original message.
- ❖ Attacker indulges in monitoring the data transmission and **aims to obtain information** in transit.
- ❖ This attack is harder to detect, since attack does not involve actively in the communication.
- ❖ Two common passive attacks:
 - **Release of message contents.**
 - **Traffic analysis.**



(a) Release of message contents



(b) Traffic analysis

Security Threats / Attacks – Active Attacks

- ❖ Active attack **involves modification of the original message** or the creation of false message.
- ❖ This attack cannot be prevented easily, since the attacks can be in the form of **interruption, modification** and **fabrication**.
- ❖ Detected with some effort and attempts can be made to recover from them
- ❖ Common active attacks:
 - **Masquerade**
 - **Replay attacks**
 - **Modification of message**
 - **Denial of service**

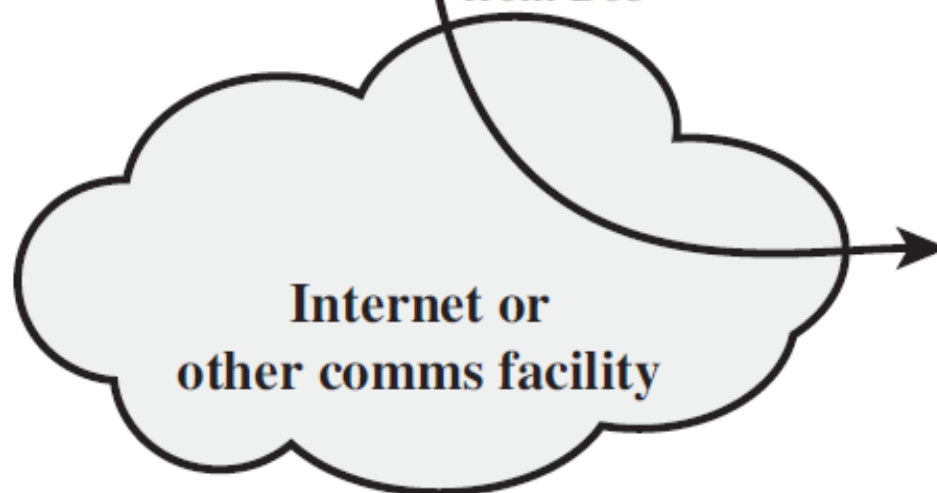


Darth

Message from Darth
that appears to be
from Bob



Bob

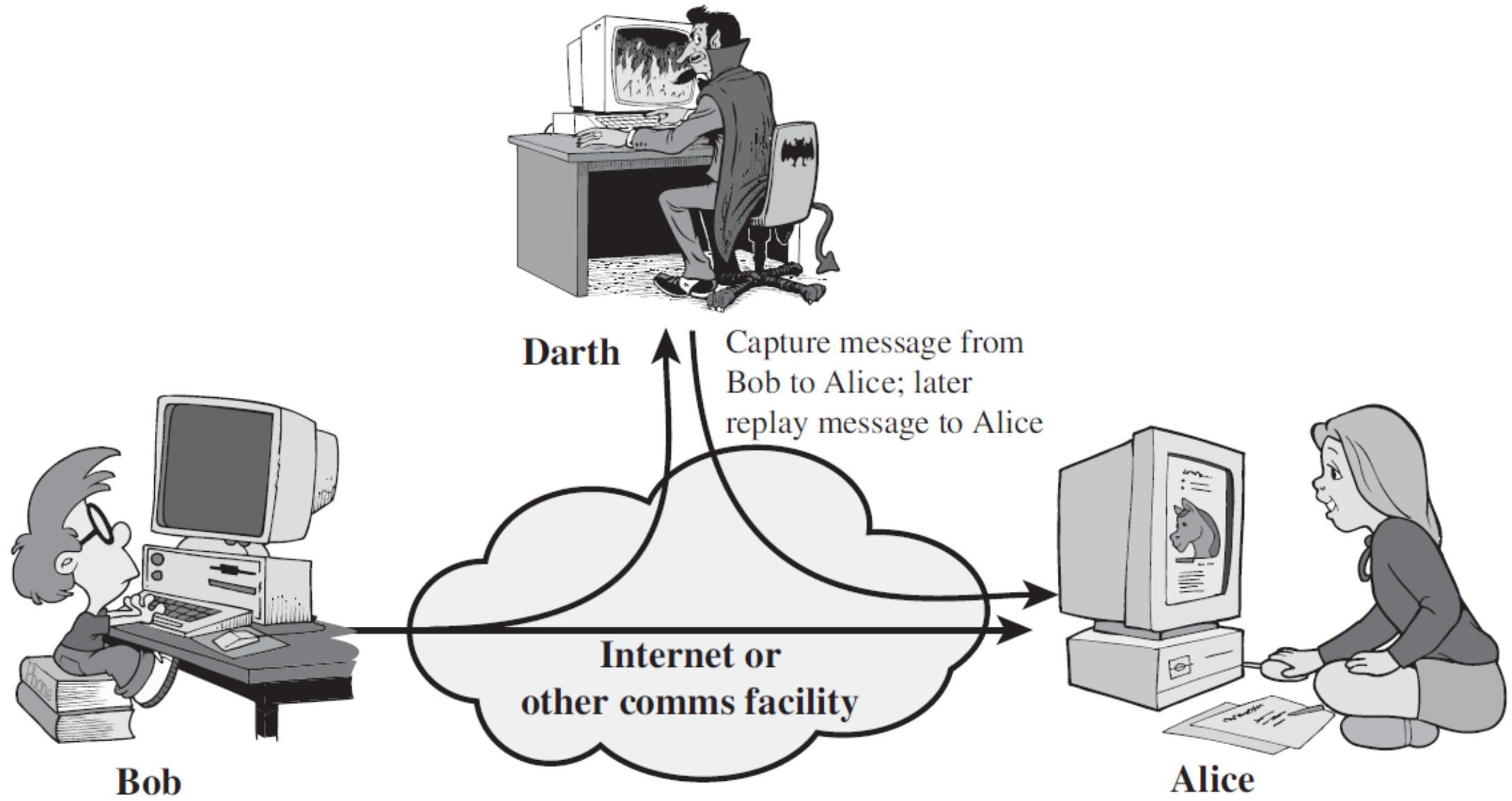


**Internet or
other comms facility**

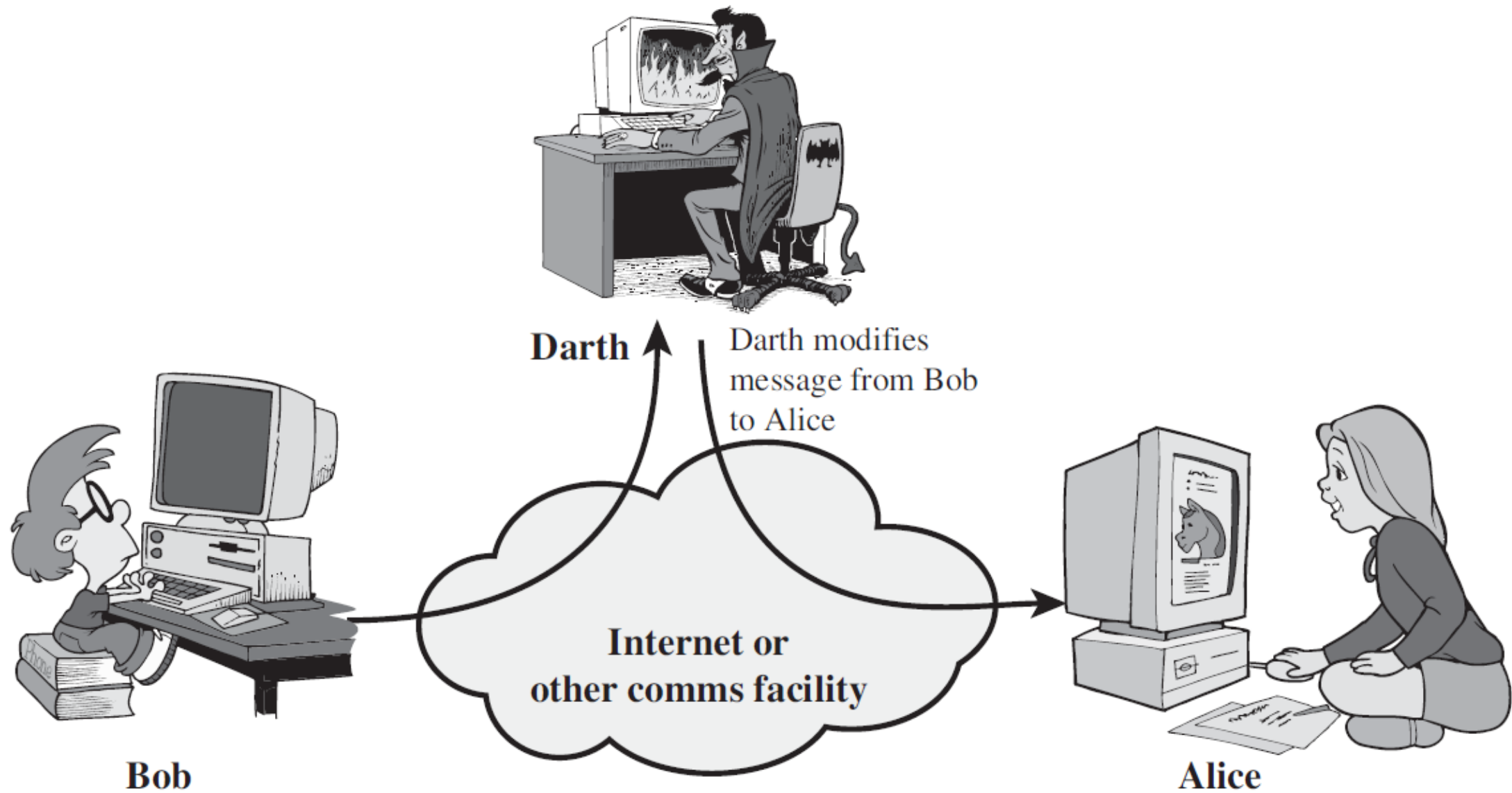


Alice

(a) Masquerade



(b) Replay



(c) Modification of messages

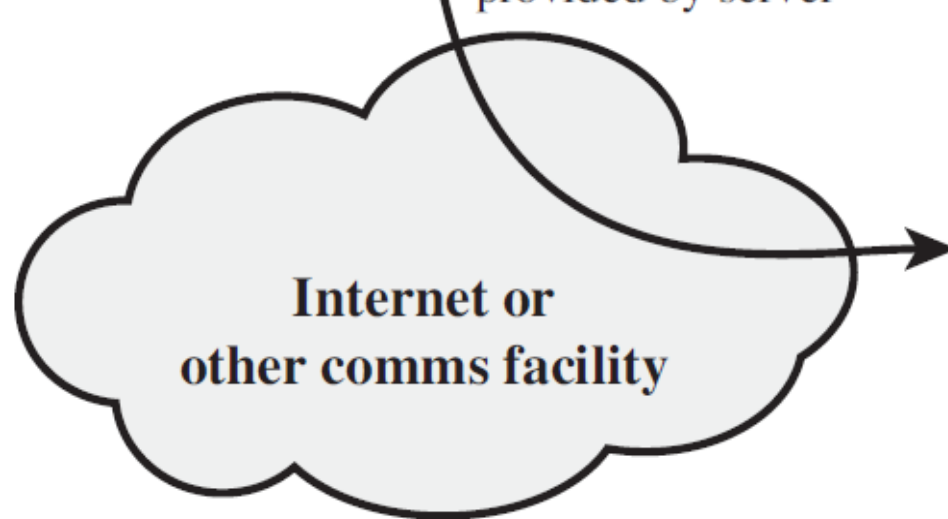


Darth

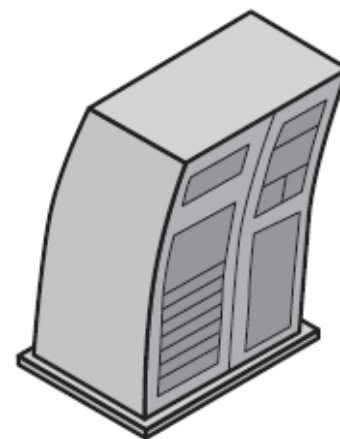
Darth disrupts service
provided by server



Bob



Internet or
other comms facility



Server

(d) Denial of service



SECURITY SERVICES

Security Services - Analogy

❑ Related to **a particular message**.

- Assume that Alice wants to send a cheque to Bob. Alice will write the cheque, put it inside the envelope and send it to Bob. Now the **concerns** of Alice and Bob:
 - Alice would like to ensure that no one except Bob gets the envelope - principle of **confidentiality** (that assets are accessible only by authorized part).
 - Alice and Bob would like to make sure that no one can tamper with the contents of the cheque - principle of **integrity** (that assets can be modified only by authorized party or in authorized ways).
 - Bob would like to be assured that the cheque has come from Alice and not from someone else - principle of **authentication**.
 - Bob deposits cheque, money is transferred and then Alice refuses having sent the check. Court of law will use Alice's signature to settle the dispute - principle of **non-repudiation**.

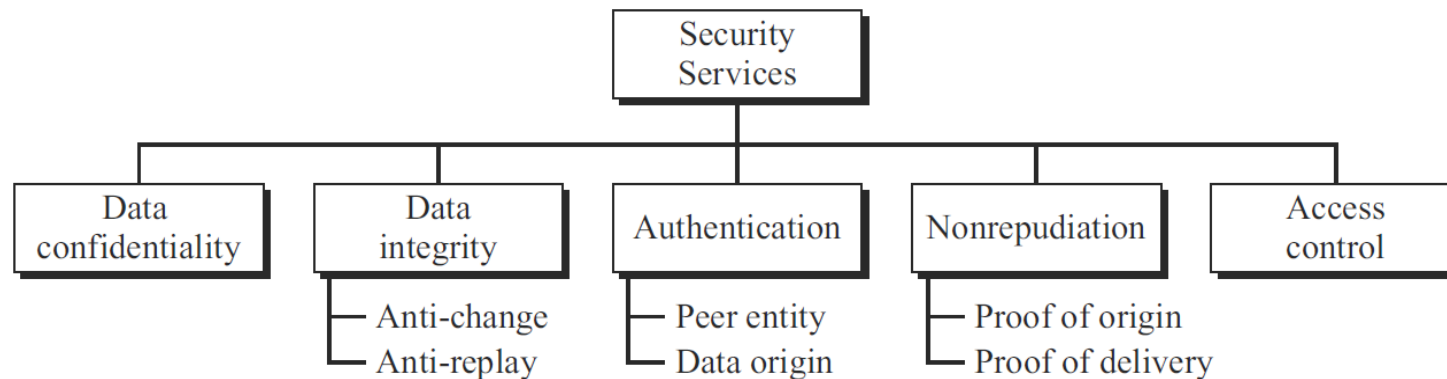
Security Services - Analogy

- ❑ Related to **overall system**.
- **Access Control**
- **Availability**
 - Assets are accessible to authorized party

Security Services – X.800 (Overall)

- ❑ X.800 has defined **five security services** provided by a protocol layer of a communicating open systems, which ensures adequate security of the systems of data transfer.
- ❑ More information can be found in **RFC 2828** (Request for Comments: 2828).

Figure 1.3 *Security services*



Security Services – Confidentiality

- The protection of data from unauthorized disclosure.
- ❖ **Connection confidentiality**: The protection of all user data on a connection
- ❖ **Connectionless confidentiality**: The protection of all user data in a single data block
- ❖ **Selective-Field Confidentiality**: The confidentiality of selected fields within the user data on a connection or in a single data block
- ❖ **Traffic Flow Confidentiality**: The protection of the information that might be derived from observation of traffic flows

Security Services – Authentication

❑ The assurance that the communication entity is the one that it claims to be.

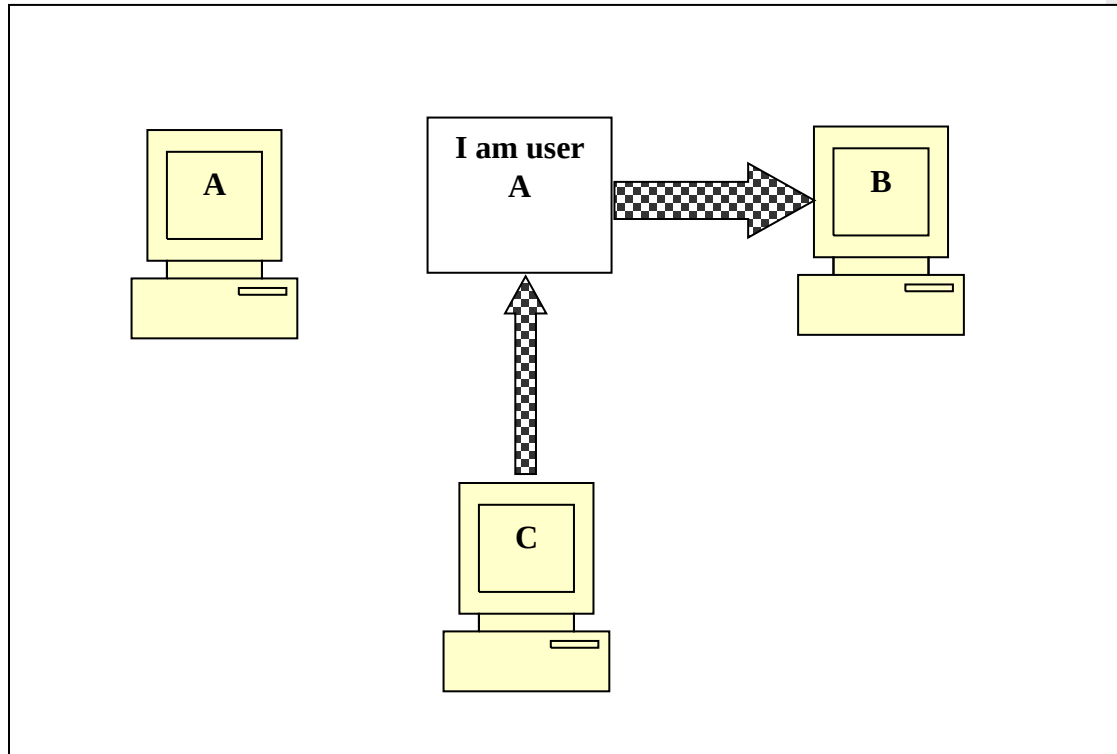
1. Single message:

- To assure the recipient that the message is from the source that it claims to be from

2. Ongoing interaction:

- At the time of connection initiation, the service assures that the two entities are authentic (each is the entity that it claims to be).
- The service must assure that the connection is **not interfered** with in such a way that a **third party can masquerade** as one of the two legitimate parties for the purposes of unauthorized transmission or reception.

Security Services – Authentication



Example:

- User C, posing as User A sending a funds transfer request to bank B from A's account to C's account
- **Type of attack - Fabrication**
 - Fabrication is possible in the **absence** of proper authentication mechanisms.

Security Services – Authentication

- **Peer Entity Authentication:**
 - Used in association with a logical connection to provide confidence in the identity of the entities connected.
 - It is provided for use at the establishment of the connection or during the data transfer phase of a connection.
- **Data origin authentication:**
 - In a connectionless transfer, provides assurance that the source of received data is as claimed.
 - It supports applications like electronic mail.

Security Services – Integrity

- ❑ The assurance that **data received are exactly as sent** by an authorized entity (i.e., contain no modification, insertion, deletion, or replay).

1. Connection Integrity **with** Recovery

- Provides for the integrity of all user data on a connection and detection of any modification, insertion, deletion, or replay of any data within an entire data sequence, with recovery attempted

2. Connection Integrity **without** Recovery

- Same as above but only provide detection without recovery

Security Services – Integrity

3. Selective-Field **Connection** Integrity

- Provides for the integrity of selected fields within the user data of a data block transferred over a connection to determine whether the selected fields have been modified, inserted, deleted or replayed.

4. **Connectionless** Integrity

- Provides for the integrity of a single connectionless data block that can be in the form of detection of data modification and detection of limited form of replay.

5. Selective-Field **Connectionless** Integrity

- Provides for the integrity of selected fields within a single connectionless data block to determine whether the selected fields have been modified.

Security Services – Non-Repudiation

- ❑ Provides **protection against denial** by one of the entities involved in a communication of having participated in all or part of the communication.
- 1. Nonrepudiation, **Origin**
 - Proof that the message was sent by the specified party.
- 2. Nonrepudiation, **Destination**
 - Proof that the message was received by the specified party.

Security Services – Non-Repudiation

Example:

- User A could send a fund transfer request to a bank over the internet.
- After the bank performs the fund transfer as per A's instructions, A could repudiate or denies funds transfer instruction.

* Non-repudiation **does not allow** the sender of a message to **refute** the claim of not sending that message.

Security Services – Access Control

- ❑ The prevention of **unauthorized use of a resource** (i.e., this service controls who can have access to a resource, under what conditions access can occur, and what those accessing the resource are allowed to do).
- ❑ **Example:**
 - Students in my Google Classroom will be able to **only view** all the materials that uploaded in the Shared folder but disallowed to make any changes or upload anything from their side.

Security Services – Access Control

□ Two common areas in access control:

1. **Role management.**

- Concentrates on the user side on what a user can (or cannot) do.

2. **Rule management.**

- Concentrates on the resources side on which resource is accessible by a particular user and under what circumstances that he can access to it.

SECURITY MECHANISMS

Security Mechanisms

- Recommendation by X.800 to provide security services defined previously.
- **Objective:**
 - To detect, prevent, or recover from a security attack.
 - Specific means of implementing one or more security service
 - No single mechanism that will support all services required
- However, one element underlies many of the security mechanisms in use -
Cryptographic Techniques

Security Mechanisms – X.800 (Overall)

❑ X.800 has defined **two major groups of security mechanisms**:

1. Specific Security Mechanisms.

- Incorporated into the appropriate protocol layer to provide some OSI security services.

2. Pervasive Security Mechanisms.

- Not specific to any OSI protocol layer or any OSI security service.

* In this course, we **DO NOT** consider the **pervasive** group.

Security Mechanisms – X.800

❑ Encipherment

- Use of **mathematical algorithms** to transform data into not intelligible form.
- Transformation and recovery depend on an algorithm and zero or more encryption keys.

❑ Digital Signature

- Data added to a data unit that allows the receiver to prove the source and **integrity** of data and protect against forgery.

❑ Access Control

- Mechanisms to enforce access rights to resources.

❑ Notarization

- Use of **trusted third party (TTP)** to assure certain properties of data exchange.

Security Mechanisms – X.800

❑ Data Integrity

- Mechanisms to assure the **integrity** of a data unit or a stream of data.

❑ Authentication Exchange

- Mechanism to ensure the identity by information exchange.

❑ Traffic Padding

- Insertion of bits in a data stream to avoid **traffic analysis**.

❑ Routing Control

- Selection of physically secure routes for data.
- Allow routing change for the suspected violation of security.

Security Services and Mechanisms

- The relationship between security services and security mechanisms:

Table 1.4 Relationship Between Security Services and Mechanisms

Service	Mechanism							
	Encipherment	Digital Signature	Access Control	Data Integrity	Authentication Exchange	Traffic Padding	Routing Control	Notarization
Peer Entity Authentication	Y	Y			Y			
Data Origin Authentication	Y	Y						
Access Control			Y					
Confidentiality	Y						Y	
Traffic Flow Confidentiality	Y					Y	Y	
Data Integrity	Y	Y		Y				
Nonrepudiation		Y		Y				Y
Availability				Y	Y			

Chapter 1

Introduction to Cryptography and Data Security (26.03.2024)





NETWORK SECURITY MODELS

Model for Network Security

- ❖ It models an information flowing over an insecure communications channel, in the presence of possible opponents (attackers/adversaries).
- ❖ An appropriate **security transformation (encryption algorithm)** can be used, with suitable **keys** (a secret information shared only by the authorized entities), possibly negotiated using the presence of a **trusted third party**.
- ❖ **Trusted Third Party (TTP):**
 - A third party that may be responsible for **key distribution**.
 - A third party that may be needed to **authenticate** the communicating parties/message sent.

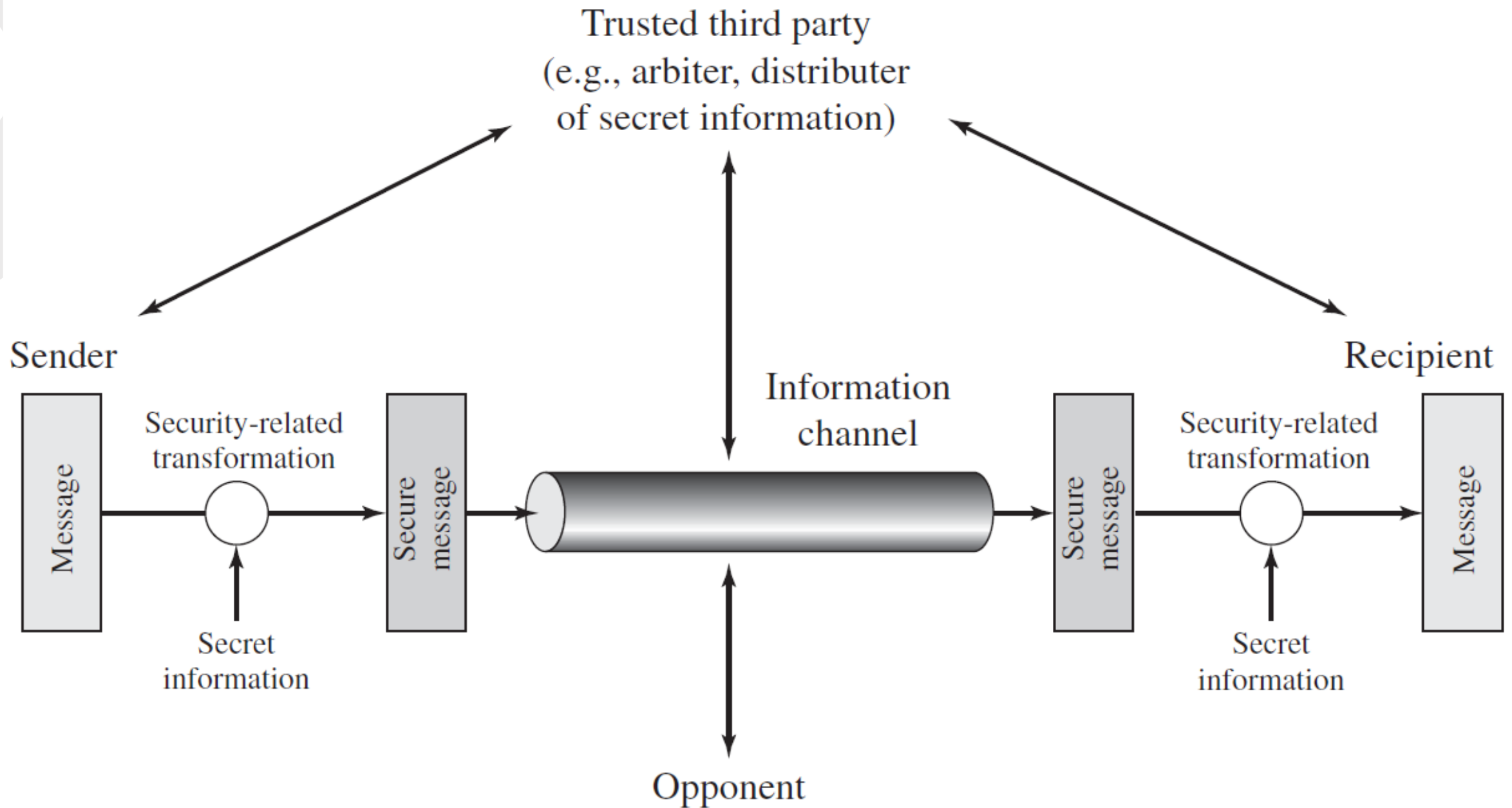


Figure 1.4 Model for Network Security

Model for Network Security

❑ Four basic tasks in designing a security service:

1. Design a suitable algorithm (via **cryptography**) for the security-related transformation. The algorithm should be impossible (or at least difficult) for an opponent to defeat its purpose.
2. Generate the secret information (that is, the **secret key**) used with the algorithm.
3. Develop methods (common via **a TTP**) to distribute and share the secret information.
4. Specify a protocol enabling the principals to use the transformation and secret information for a security service.

Network **Access** Security Model

- ❖ A model that is concerned with controlled access to information or resources on a computer system, in the presence of possible opponents.
- ❖ Two possible kinds of threats:
 - **Information access threats:** It intercepts or modifies data on behalf of users who should not have access to that data.
 - **Service threats:** It exploits service flaws in computers to inhibit use by legitimate users.
- ❖ Appropriate controls are needed on the access and also within the system, to provide suitable security. In some cases, cryptographic techniques are useful too.

Network Access Security Model

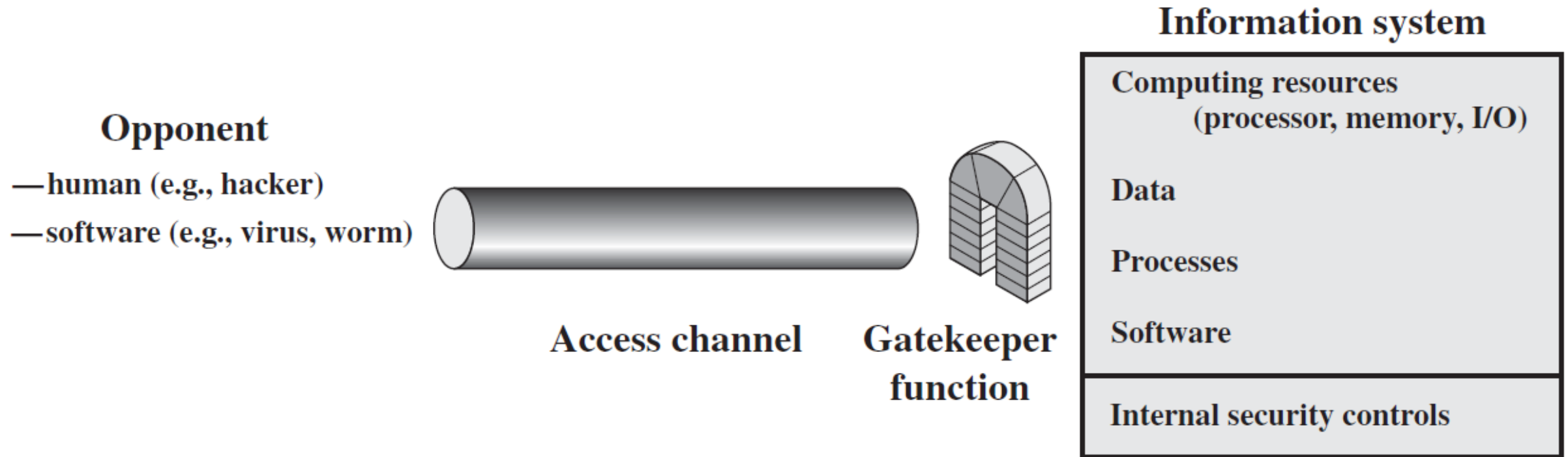


Figure 1.5 Network Access Security Model

Network Access Security Model

- ❑ **Two broad categories** of security mechanisms needed to cope with unwanted access:
 1. Select appropriate **gatekeeper functions**:
 - To include password-based login procedures to allow only authorized users.
 - To include screening logic to detect and reject worms, viruses and similar attacks.
 2. Implement **internal security controls** to monitor activity and analyse stored information to detect the presence of unwanted intruders or virus.



PART 2: **CRYPTOGRAPHY**

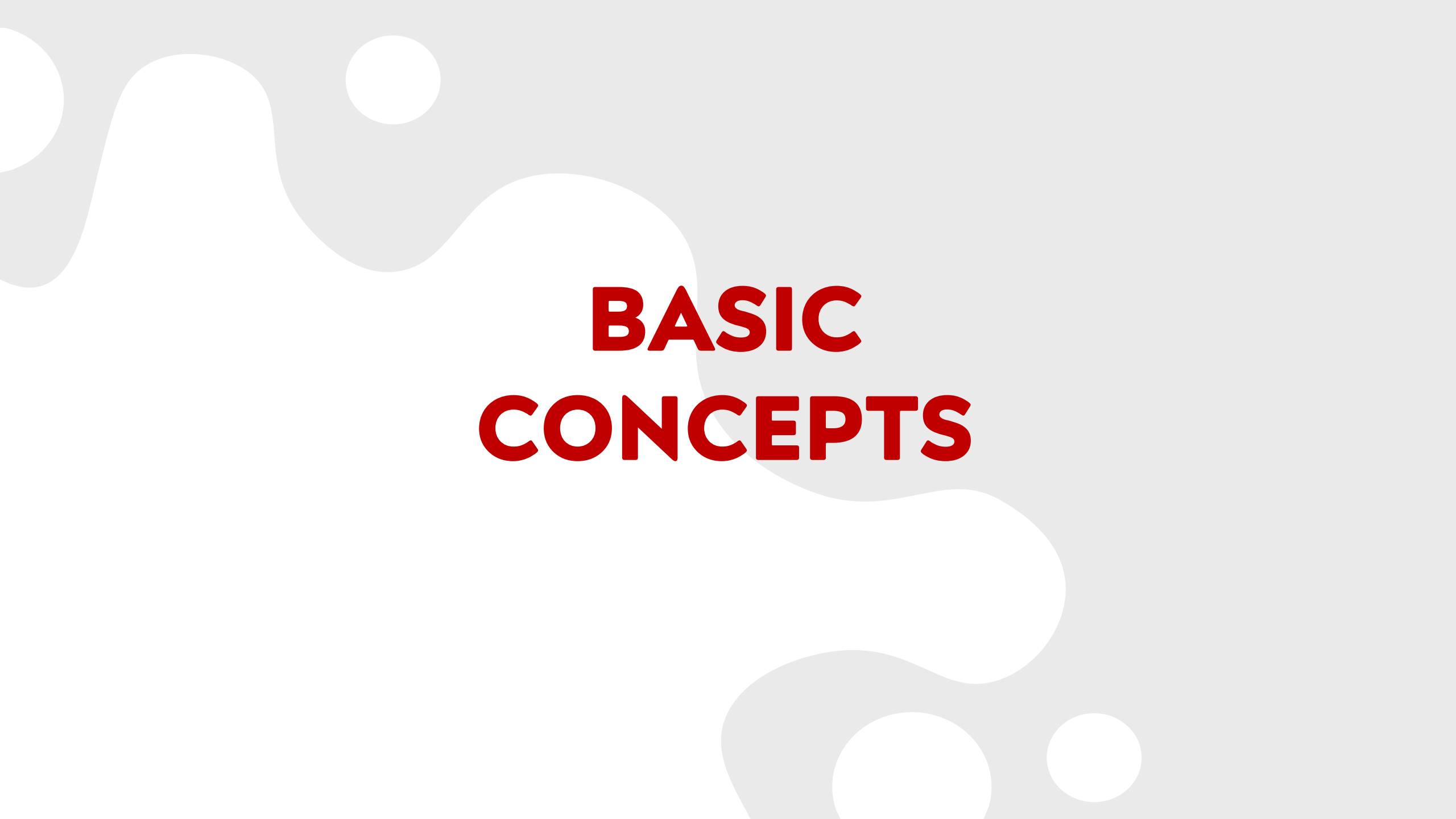
Outlines

1. Basic terminologies.
2. Kerckhoffs' Principle.
3. Security Levels.
4. Types of Cryptography.
5. Types of Cryptanalysis.

Learning Objectives

In the end of this Part 2, students should be able:

1. To understand the **terms** used in describing cryptography.
2. To understand the **Kerckhoffs' principle** and its importance in cryptology.
3. To understand the difference of the **security levels** defined in cryptography.
4. To understand and differentiate different types of **cryptography**.
5. To understand and differentiate different types of **cryptanalysis**.



BASIC CONCEPTS

Basic Terminology – Cryptology

Cryptology is a study covers two major areas:

1. Cryptography

- A word with Greek origins – **secret writing**.
- The science and art of transforming messages to make them secure (**unreadable** by unauthorized users) and immune to attacks (**irrecoverable** by attackers).
- Practitioners in this area is called **Cryptographers**.

2. Cryptanalysis

- Techniques used for deciphering a message **without** any knowledge of the enciphering details (**without using keys**).
- Practitioners in this area is called **Cryptanalysts**.

Basic Terminology – Cryptology

3. Plaintext or Message

- The original **intelligible** message understood by anyone. It can be understood by the sender, the recipient, and by whoever gets an access to that message.

4. Ciphertext

- The encrypted message output from some algorithms. It is a random string of data that is **unintelligible**.

5. Encryption Algorithm

- An algorithm used to **transform** plaintext into ciphertext.

6. Decryption Algorithm

- An algorithm used to **transform** ciphertext into plaintext.

Basic Terminology – Cryptology

7. **Secret Key**

- A **secret information** used in encryption known only to sender/receiver.

8. **Encryption (Encipherment)**

- The process of converting from plaintext to ciphertext using a cipher and secret key(s).

9. **Decryption (Decipherment)**

- The process of recovering plaintext from ciphertext using a cipher and secret key(s).

Kerckhoffs' Principle

In the 19th century, a Dutch-born cryptographer Auguste Kerckhoffs came out one of the most important design principles for encryption, which now famously known as the **Kerckhoffs' principle**, states that:

*The cipher method (encryption) must **NOT** be required to be secret, and it must be able to fall into the hands of the enemy without inconvenience.*

Kerckhoffs' Principle

In other words, the **security** of an cryptographic algorithm lies on the **secrecy of the KEYS**, not the algorithm itself.

Guessing / finding the key must be **difficult** for an attacker. Hence, the **key domain** must be large enough to achieve such an objective.

Security Levels

1. Unconditional Security

- Regardless of endless computer power, the ciphertext cannot be broken since the ciphertext provides insufficient information to uniquely determine the corresponding plaintext.
- No encryption algorithm is **unconditionally secure** except the **one-time pad scheme**.

2. Computational Security

- The **cost** of breaking the cipher exceeds the value of the encrypted information.
- The **time** required to break the cipher exceeds the useful lifetime of the information.
- If either of the above criteria is met, an encryption scheme is said to be **computationally secure**.

Cryptography (Overall)

❖ Generally, a cryptographic scheme (or simply **cryptosystem**) consists of the following **three** algorithms:

1. **Key Generation algorithm**: On input of security parameter n , it generates system parameters. These system parameters include a description of **finite message** space $\mathfrak{M}$, a **finite ciphertext** space $\mathfrak{C}$, and a **finite key** space $\mathfrak{K}$.
 2. **Encryption algorithm**: On input of system parameters, a message $M \in \mathfrak{M}$, and a key $K \in \mathfrak{K}$, it outputs a ciphertext $C \in \mathfrak{C}$. Mathematically, $C = \text{Enc}(M, K)$.
 3. **Decryption algorithm**: On input of system parameters, a ciphertext $C \in \mathfrak{C}$, and a key $K \in \mathfrak{K}$, it returns a message $M \in \mathfrak{M}$. Mathematically, $M = \text{Dec}(C, K)$.
- Hence, encryption and decryption are **inverse** to each other: $M = \text{Dec}(\text{Enc}(M, K), K)$.

Cryptography (Overall)

○ Different cryptosystem features different settings in their algorithms:

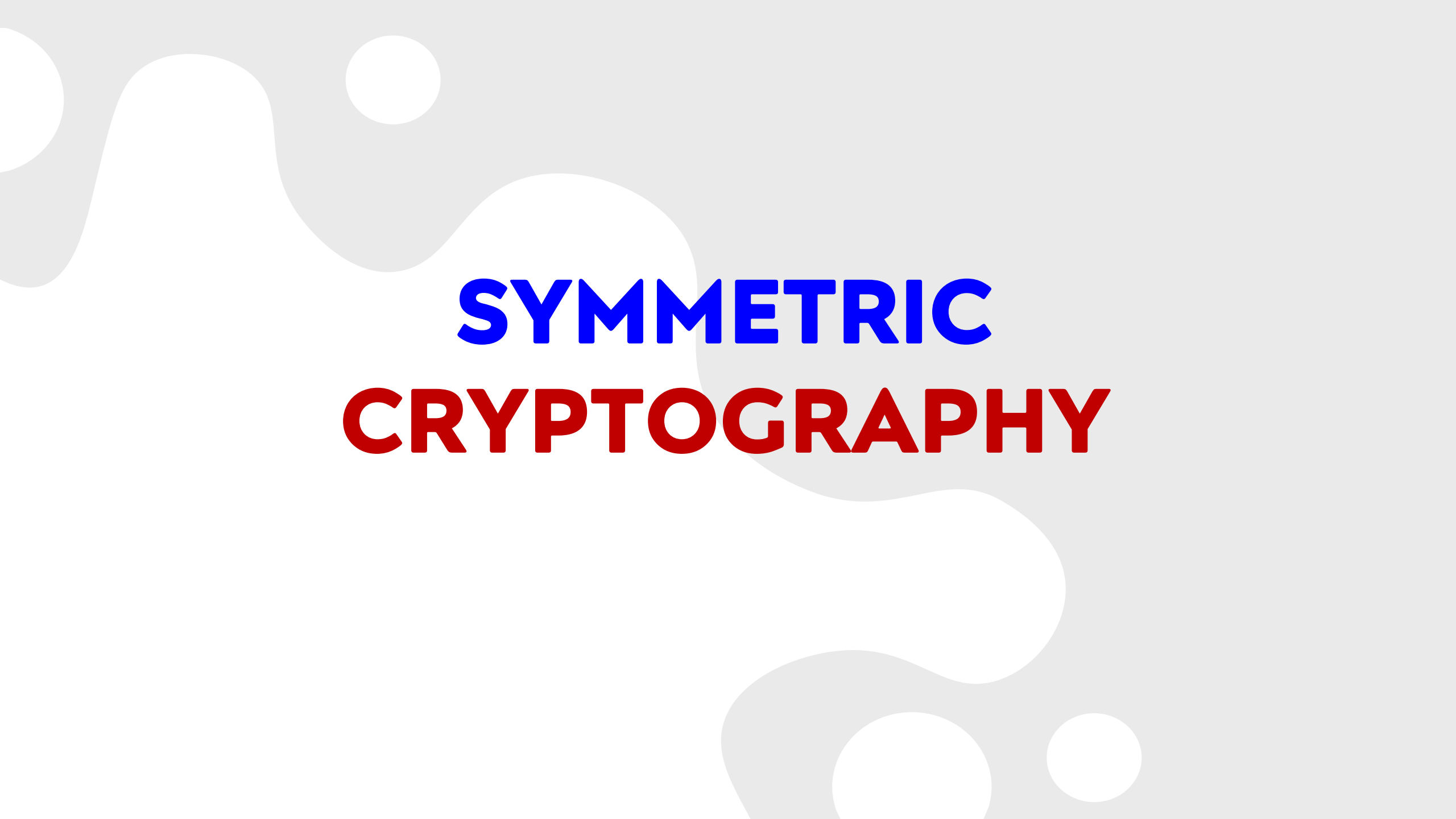
1. Amount of keys involves:

- Hash Functions: 0 key.
- **Symmetric cryptography**: 1 key.
- **Asymmetric cryptography**: 2 keys.

2. Types of encryption operations: Substitution, transposition, product, etc.

3. Techniques in processing the plaintext (message):

- Stream cipher.
- Block cipher.



SYMMETRIC CRYPTOGRAPHY

Symmetric Cryptography

Also known as **secret/private-key cryptography**.

- Both sender and receiver **share a common secret key**.
- If this key is disclosed, then the communication is compromised.
- It relies on the fundamental building blocks of substitution and permutation (transposition).

It is **symmetric** since both parties are equally having the same secret key.

- Hence does not protect sender from receiver forging a message (**integrity**) and claiming it is sent by sender (**non-repudiation**).

All classical encryption algorithms are secret-key type and were only the type prior to invention of public-key in the 1970s.

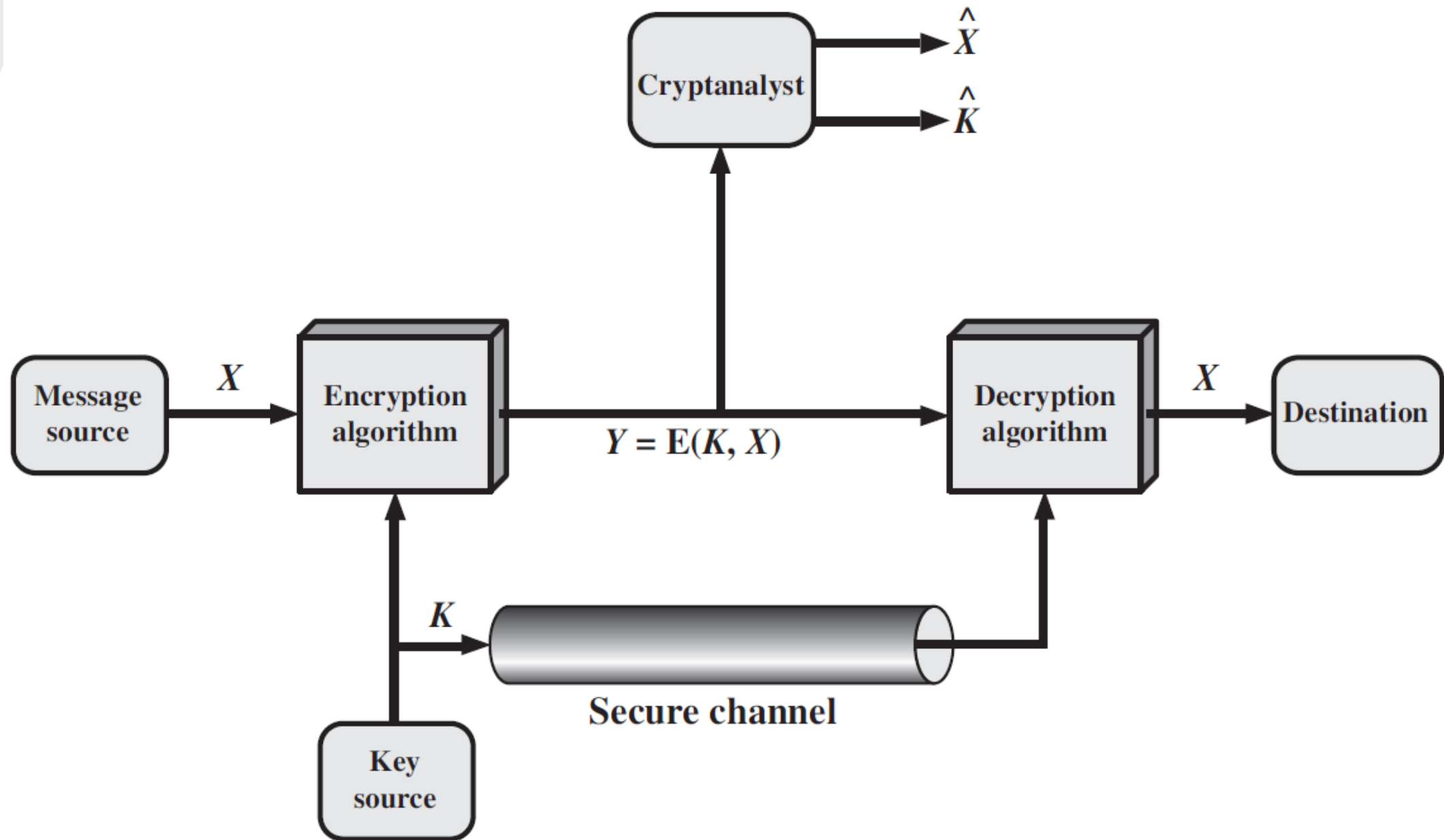


Figure 2.2 Model of Symmetric Cryptosystem

Ingredients of Symmetric Cryptography

1. **Plaintext:** The original intelligible message or data.
2. **Encryption algorithm:** It performs various transformations on the plaintext.
3. **Secret key:** It controls the exact substitutions or transformations used in encryption algorithm. The key is a value **independent** of the plaintext and of the algorithm. The algorithm produces different output depending on the specific key used at the time (**random / probabilistic**).
4. **Ciphertext:** An output that depends on the input plaintext and the secret key.
5. **Decryption algorithm:** It is an inverse of encryption algorithm that takes the ciphertext and secret key and returns the original plaintext.

Model of Symmetric Cryptography

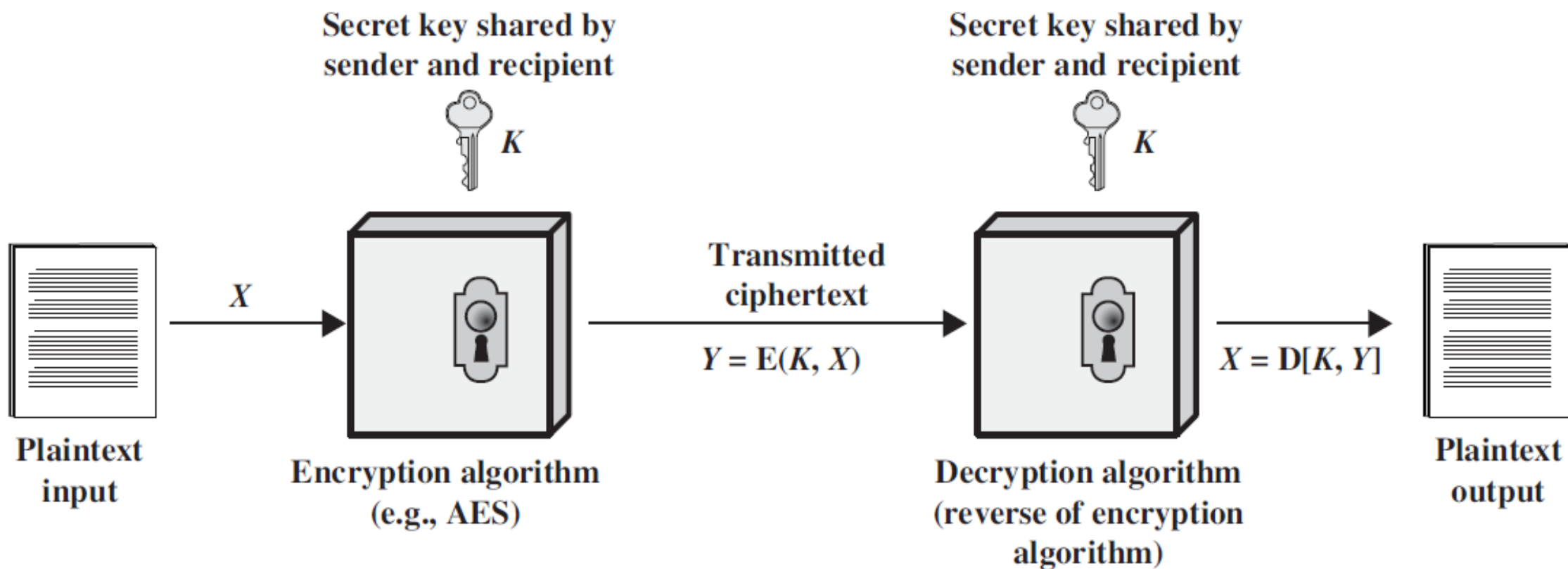


Figure 2.1 Simplified Model of Symmetric Encryption

Requirements of Symmetric Cryptography

For a secure use of symmetric cryptography:

1. A strong encryption algorithm is needed.

- The opponent should be **unable to decrypt** ciphertext or **to discover the key** even if he or she is in possession of several ciphertexts together with the plain text that produced each ciphertext.

2. The secret key should be known only to sender and receiver.

- A **secure secret-key distribution** is required to transfer the keys to the intended receiver.
- The secret key must be **kept and protected securely** from any malicious party.



ASYMMETRIC CRYPTOGRAPHY

Asymmetric Cryptography

Also known as **Public-key Cryptography**.

- Two keys are used: one **public key** and one **private key**.
- To send a secure message, sender first encrypts the message using receiver's public key.
- To decrypt the message, receiver uses his/her own private key.

It is **asymmetric** since anyone knowing the public key **can encrypt** messages or verify signatures, but **cannot decrypt** messages or create signatures

It uses clever application of **number theory (mathematics)** concepts.

It **complements** rather than replaces private key cryptosystem.

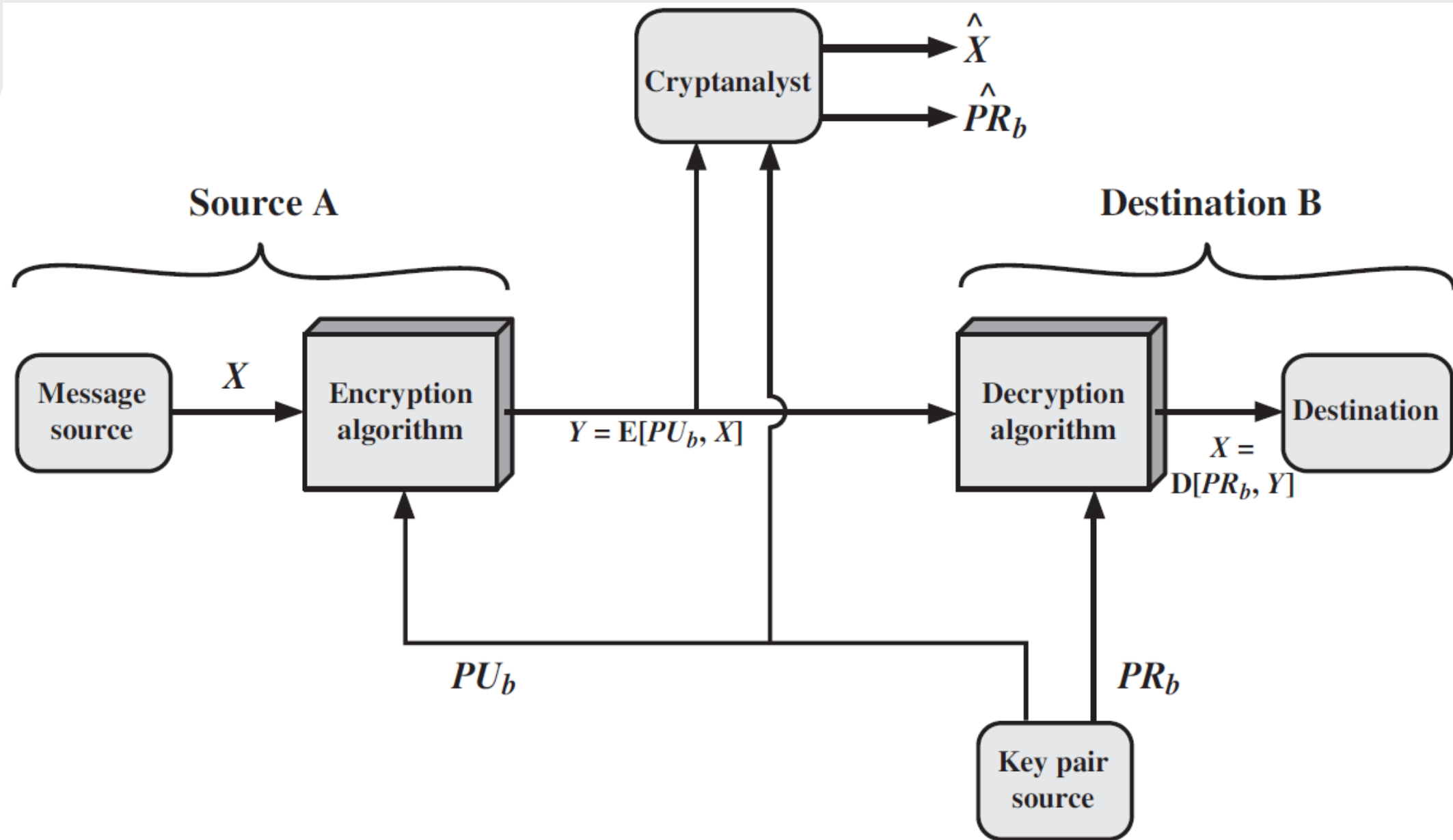


Figure 9.2 Public-Key Cryptosystem: Secrecy

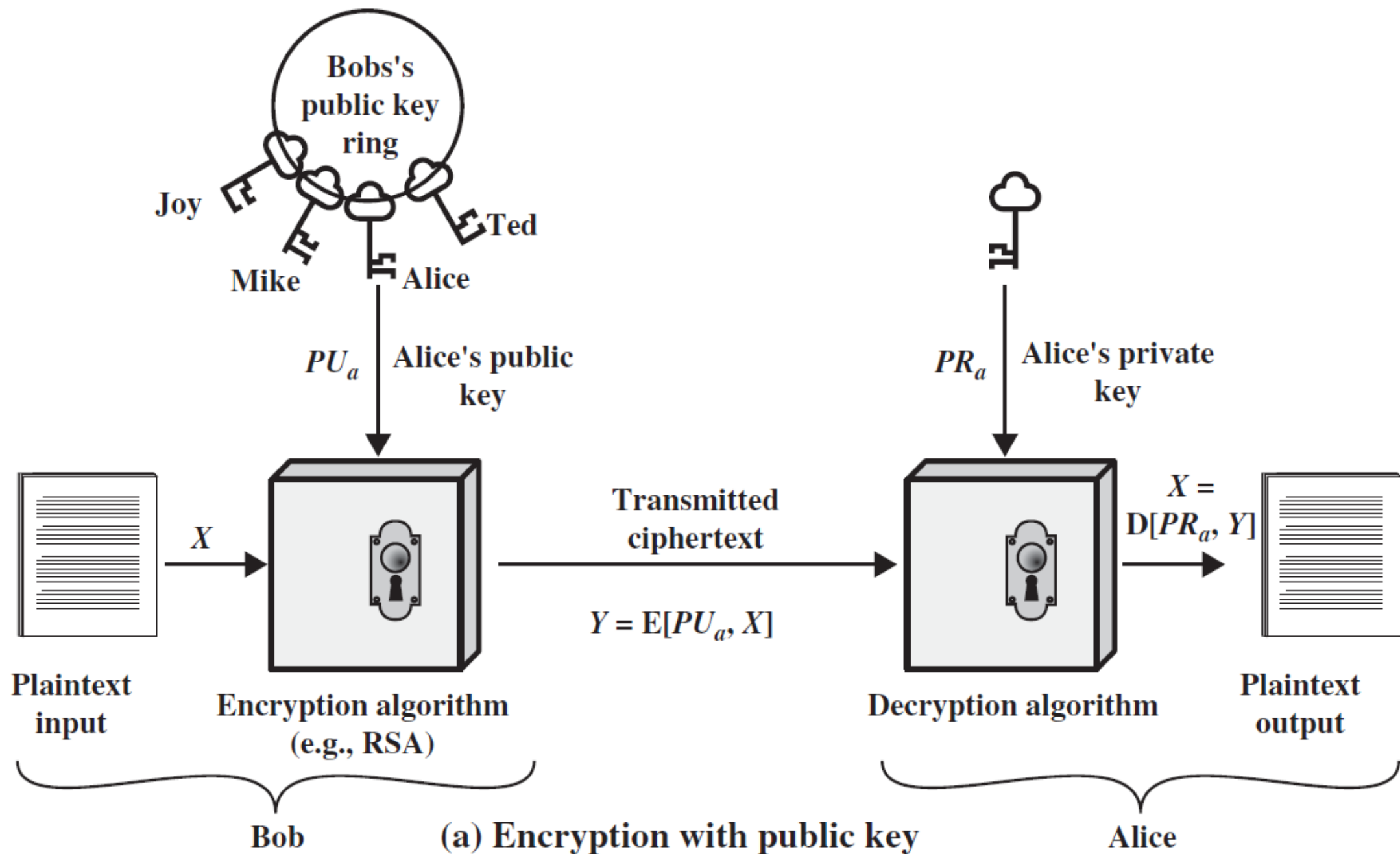
Asymmetric Cryptography - Analogy

Consider the following **analogies** using padlocked boxes:

1. Private key cryptography involve the sender putting a message in a box and locking it, sending that to the receiver, and somehow securely also sending them the key to unlock the box.
2. The radical advance in public key cryptography change the environment:
 - The receiver sends an **unlocked box** (his **public key**) to the sender, who puts the message in the box and locks it (easy and having locked, it is impossible to take out the message anymore), and sends the locked box to the receiver who can unlock it (also easy) with his **private key**.
 - An attacker would have to identify the private key to unlock the box (hard).

Ingredients of Asymmetric Cryptography

1. **Plaintext:** The original intelligible message or data.
2. **Encryption algorithm:** It performs various transformations on the plaintext.
3. **Public-Private keys:** A pair of keys that have been selected so that if one is used for encryption, the other is used for decryption. The exact transformations performed by the algorithm depend on the public or private key that is provided as input
4. **Ciphertext:** An output that depends on the input plaintext and the secret key.
5. **Decryption algorithm:** It is an inverse of encryption algorithm that takes the ciphertext and secret key and returns the original plaintext.



Asymmetric Cryptography – Essential Steps

1. Each user **generates a pair of keys** to be used for the encryption and decryption of messages.
2. Each user **places one of the two keys in a public register** or other accessible file. This is the **public key**. The companion key is kept private. As the previous figure suggests, each user maintains a collection of public keys obtained from others.
3. If Bob wishes to send a confidential message to Alice, Bob **encrypts** the message using **Alice's public key**.
4. When Alice receives the message, she **decrypts** it using **her private key**. No other recipient can decrypt the message because only Alice knows Alice's private key.

Symmetric vs Asymmetric Cryptography

Conventional Encryption	Public-Key Encryption
<i>Needed to Work:</i> 1. The same algorithm with the same key is used for encryption and decryption. 2. The sender and receiver must share the algorithm and the key. <i>Needed for Security:</i> 1. The key must be kept secret. 2. It must be impossible or at least impractical to decipher a message if no other information is available. 3. Knowledge of the algorithm plus samples of ciphertext must be insufficient to determine the key.	<i>Needed to Work:</i> 1. One algorithm is used for encryption and decryption with a pair of keys, one for encryption and one for decryption. 2. The sender and receiver must each have one of the matched pair of keys (not the same one). <i>Needed for Security:</i> 1. One of the two keys must be kept secret. 2. It must be impossible or at least impractical to decipher a message if no other information is available. 3. Knowledge of the algorithm plus one of the keys plus samples of ciphertext must be insufficient to determine the other key.

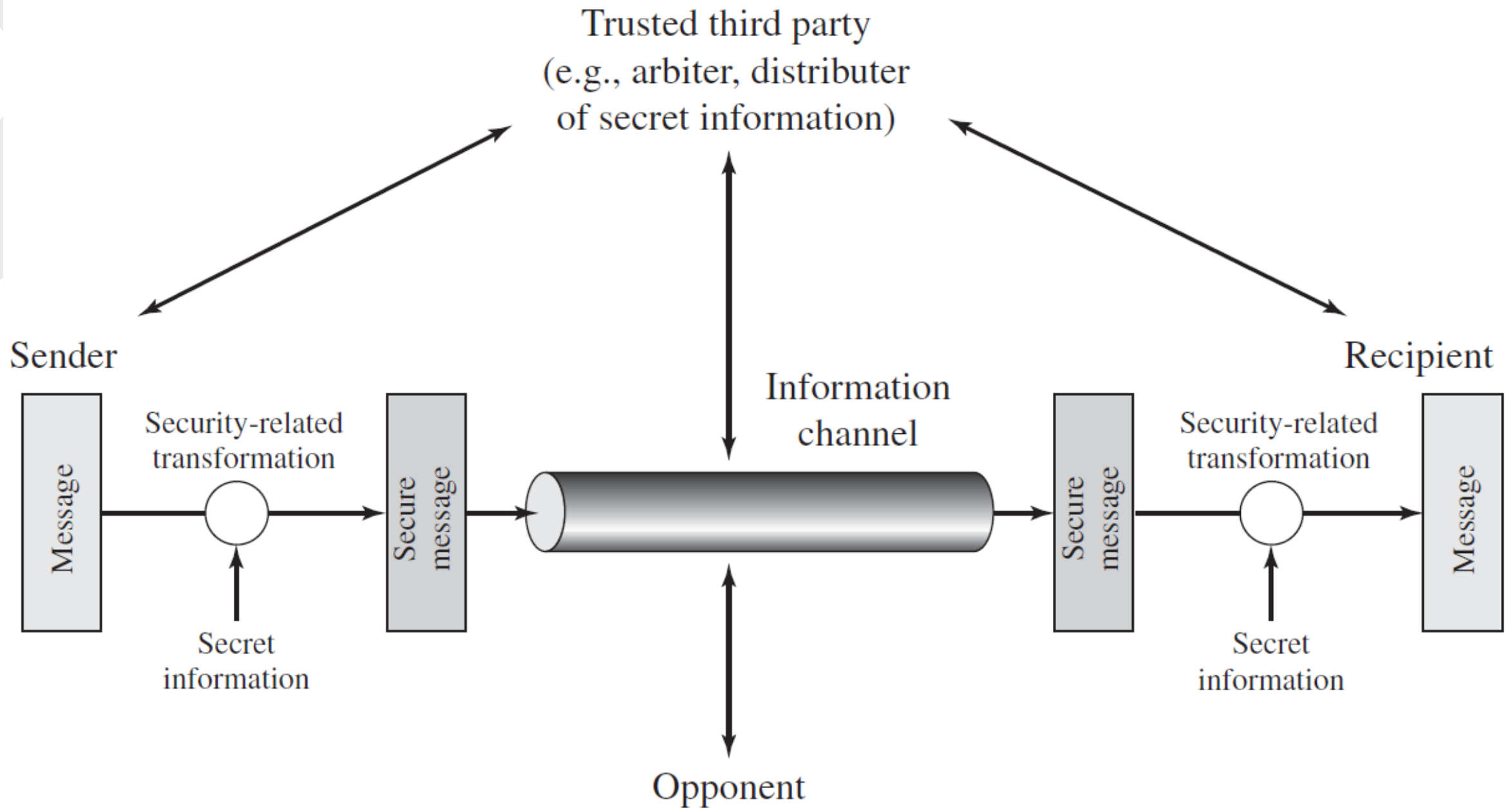


Figure 1.4 Model for Network Security

CRYPTANALYSIS

Cryptanalysis

- ❑ As opposed to cryptography, cryptanalysis is **art and science of breaking the cryptography**.
- ❑ In general, there are **two approaches** in attacking cryptography:
 1. **Brute-Force attack:**
 - The attacker **tries every possible key** on a piece of ciphertext until an intelligible translation into plaintext is obtained. On average, half of all possible keys must be tried to achieve success.
 2. **Cryptanalysis:**
 - It relies on the **nature of the algorithm** in addition some knowledge of the **general characteristics of the plaintext or plaintext-ciphertext pairs**. This attack attempts to a specific plaintext, or to deduce the key used in the cryptography.

Cryptanalysis – Brute Force Attack

Table 2.2 Average Time Required for Exhaustive Key Search

Key Size (bits)	Number of Alternative Keys	Time Required at 1 Decryption/ μ s	Time Required at 10^6 Decryptions/ μ s
32	$2^{32} = 4.3 \times 10^9$	$2^{31}\mu\text{s} = 35.8$ minutes	2.15 milliseconds
56	$2^{56} = 7.2 \times 10^{16}$	$2^{55}\mu\text{s} = 1142$ years	10.01 hours
128	$2^{128} = 3.4 \times 10^{38}$	$2^{127}\mu\text{s} = 5.4 \times 10^{24}$ years	5.4×10^{18} years
168	$2^{168} = 3.7 \times 10^{50}$	$2^{167}\mu\text{s} = 5.9 \times 10^{36}$ years	5.9×10^{30} years
26 characters (permutation)	$26! = 4 \times 10^{26}$	$2 \times 10^{26}\mu\text{s} = 6.4 \times 10^{12}$ years	6.4×10^6 years

Cryptanalysis – Cryptanalytic Attacks

□ In general, there are **five common types** of cryptanalytic attacks based on **the amount of the information** (environment) an attacker has. These attacks are ranked from the weakest to the strongest.

1. Ciphertext-only Attack (COA) – **the weakest**
2. Known-Plaintext Attack (KPA)
3. Chosen-Plaintext Attack (CPA)
4. Chosen-Ciphertext Attack (CCA)
5. Chosen-Text Attack – **the strongest**

❖ The **chosen text attack** is always analysed under **CCA** in security analysis.

Table 2.1 Types of Attacks on Encrypted Messages

Type of Attack	Known to Cryptanalyst
Ciphertext Only	• Encryption algorithm • Ciphertext
Known Plaintext	• Encryption algorithm • Ciphertext • One or more plaintext–ciphertext pairs formed with the secret key
Chosen Plaintext	• Encryption algorithm • Ciphertext • Plaintext message chosen by cryptanalyst, together with its corresponding ciphertext generated with the secret key
Chosen Ciphertext	• Encryption algorithm • Ciphertext • Ciphertext chosen by cryptanalyst, together with its corresponding decrypted plaintext generated with the secret key
Chosen Text	• Encryption algorithm • Ciphertext • Plaintext message chosen by cryptanalyst, together with its corresponding ciphertext generated with the secret key • Ciphertext chosen by cryptanalyst, together with its corresponding decrypted plaintext generated with the secret key

Cryptanalysis – Ciphertext-Only Attack

❑ The attacker (Eve) has **access to only some ciphertext**, and tries to find the corresponding plaintext, or the key.

❑ Possible attacks:

1. **Brute force / exhausted key search**: Eve tries to decrypt the ciphertext using all possible keys until the plaintext makes sense.
 - **Prevention**: Apply a very large key size.
2. **Statistical attack**: Eve tries to detect some inherent characteristics of the language pattern (For example, letter 'E' has the highest frequency in English text) to search for the key used in the encryption.
 - **Prevention**: Hide the characteristics of the language.
3. **Pattern attack**: Exploit the pattern of the ciphertext.
 - **Prevention**: Randomize the output ciphertext.

Figure 3.4 *Ciphertext-only attack*

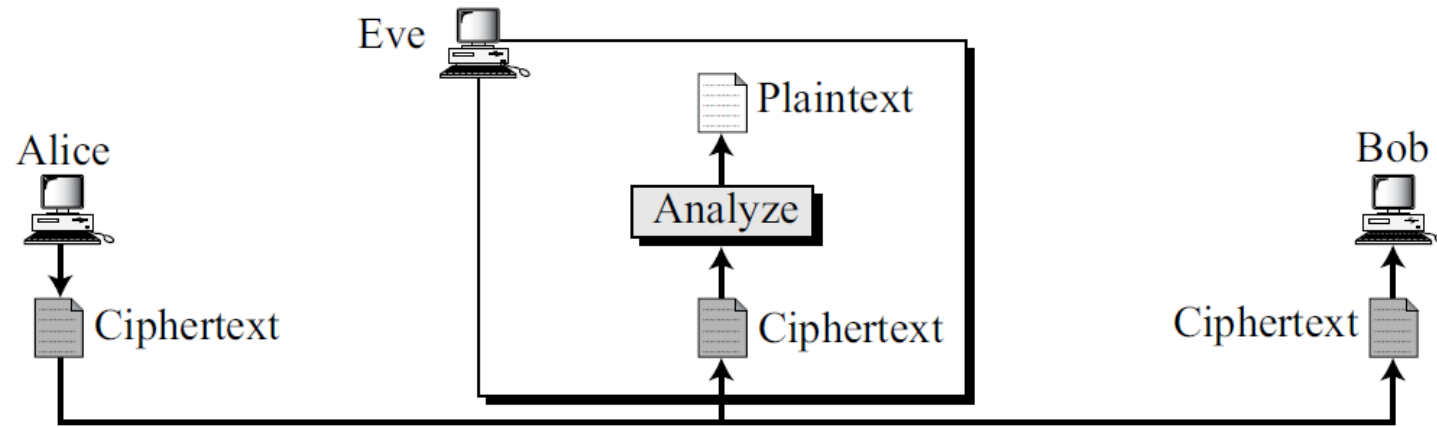
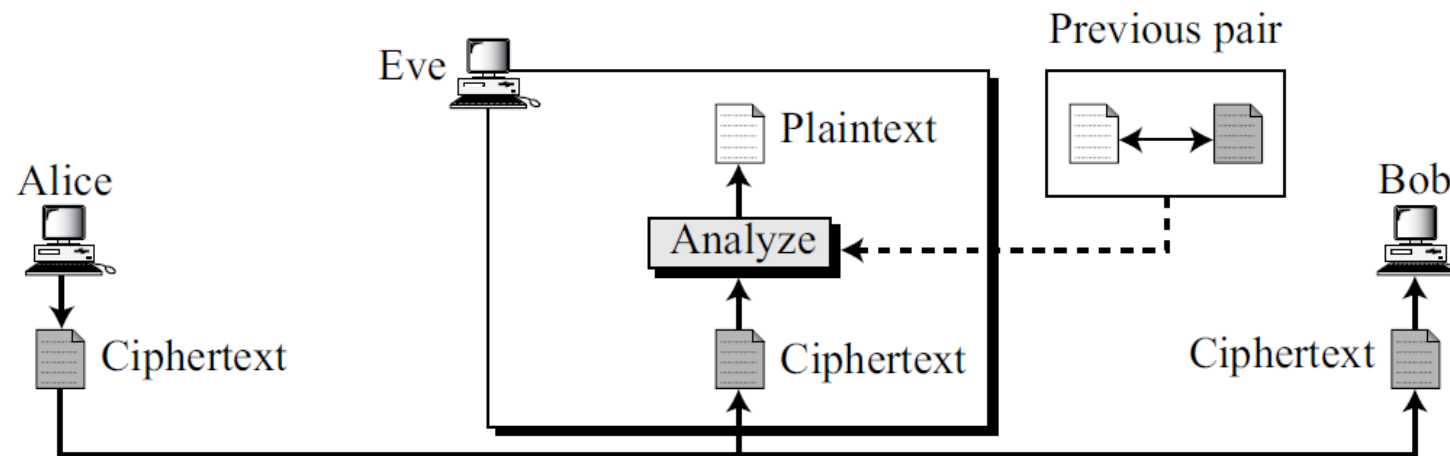


Figure 3.5 *Known-plaintext attack*



Cryptanalysis – Known-Plaintext Attack

- ❑ The attacker (Eve) **has access to some plaintext-ciphertext pairs**, in addition to the **intercepted ciphertext that she wants to break**.
- ❑ The collected pairs are used to break the **NEXT** intercepted ciphertext, assuming the **key has NOT changed**.
- ❑ All the attacks launched in COA are also applicable here.
- ❑ This attack is **easier** since Eve has now more information to aid her, but **less likely to happen** since sender may have changed the encryption key, or the previous message is not revealed.

Cryptanalysis – Chosen-Plaintext Attack

- ❑ The attacker (Eve) has **access to the plaintext-ciphertext pairs CHOSEN by herself**.
- ❑ Eve can **choose any plaintext of her choice** and ask for **encryption** to obtain the corresponding ciphertext. The output ciphertext is collected and used to attack the **NEXT** intercepted ciphertext.
- ❑ **For example:** Eve has access to the Sender's computer. She can choose some plaintext and intercept the output ciphertext. Note that Eve does not have the encryption key.
- ❑ This attack is **much easier** to implement, but **much less likely to happen**.

Figure 3.6 *Chosen-plaintext attack*

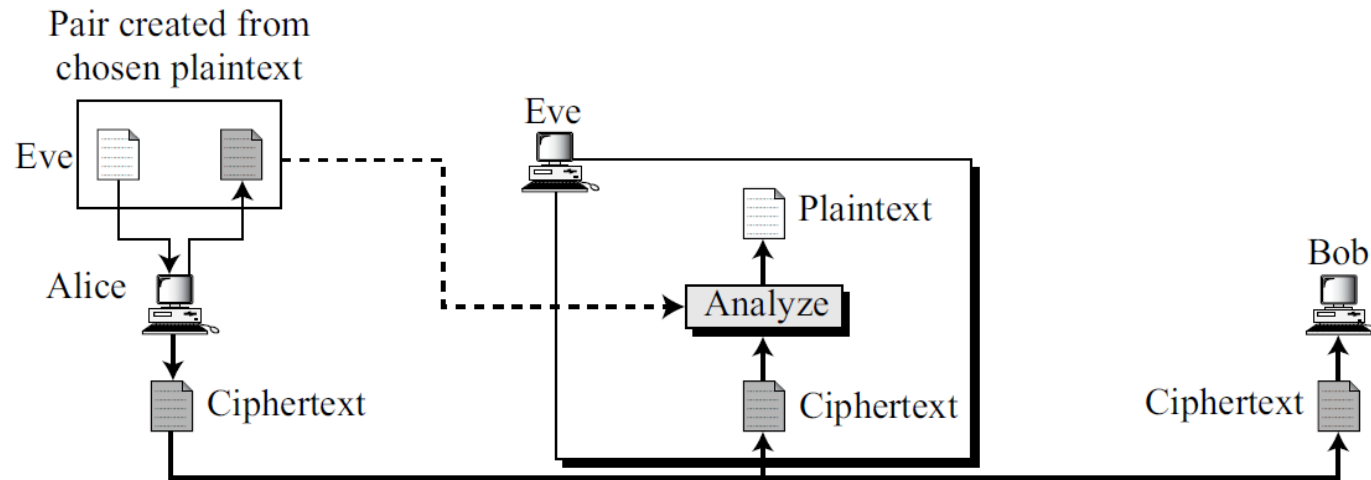
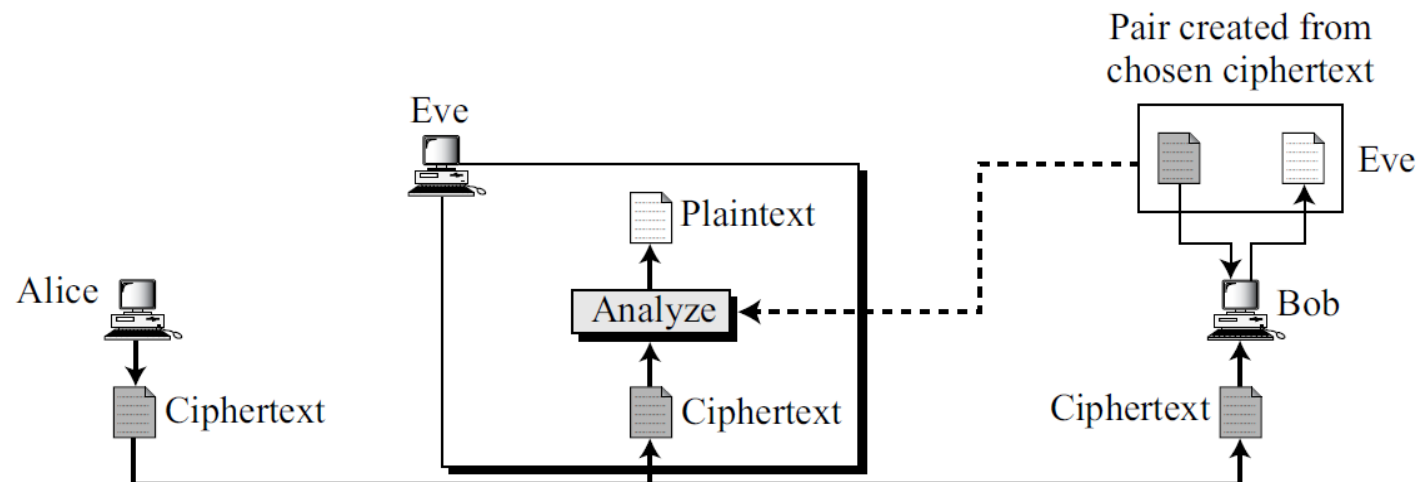


Figure 3.7 *Chosen-ciphertext attack*



Cryptanalysis – Chosen-Ciphertext Attack

- ❑ The attacker (Eve) has **access to the plaintext-ciphertext pairs CHOSEN by herself**.
- ❑ Eve can **choose any ciphertext of her choice** and ask for **decryption** to obtain the corresponding plaintext. The output plaintext is collected and used to attack the **NEXT** intercepted ciphertext.
- ❑ **For example**: Eve has access to the Receiver's computer. She can choose some ciphertext and intercept the decrypted plaintext. Note that Eve does not have the decryption key.
- ❑ This attack is **even much easier** to implement, but **very unlikely to happen**.

Cryptanalysis – Chosen-Text Attack

- ❑ A **combination of both** CPA and CCA environments.
- ❑ The attacker (Eve) acquires **the greatest (complete) attacking ability**.
- ❑ The final target is remains the same:
 1. She can **deduce the plaintext** from the intercepted ciphertext.
 2. She can **deduce the encryption and/or decryption keys** used in the communication.
- ❑ Also the easiest and provide highest ability to the attacker, this attack is rarely likely to happen.

Cryptanalysis – Security vs Attack

- ❑ In cryptography, when proposing or designing a cryptosystem, often the security analysis is given to support its protection against specific attack.
- ❑ In most cases, all designed cryptosystems are looking for CCA security. That is **we assume an attacker has the highest attacking ability**, and then we prove that **he will eventually failed in achieving his target**.
- ❑ If one can show that a cryptosystem is **secure against CCA**, then the system is considered **safe to be used in practice**.



OTHER CLASSICAL ENCRYPTION TECHNIQUE

Steganography – Classical Techniques

A method of **concealing the existence of the original message** rather than make it unreadable but does not change the original message.

Common **classical techniques**:

- **Character marking**: Uses only a subset of letters/words in a longer message marked in some way.
- **Invisible ink**: It leaves no visible trace until heat, or some chemical is applied on the paper.
- **Pin punctures**: Invisible unless the paper is held in front of light.
- **Typewriter correction ribbon**: It types with correction tape between lines typed with black ribbon – visible only under a strong light.
- **Photographing**: The secret message is **snapped** and **reduced** to a size of a dot and inserted in place of regular periods at the end of sentences.
- **Hiding in LSB**: In either **graphic image or sound file**.

Steganography – Modern Techniques

Secret binary information can be inserted into any form of data (text, image, audio, or video) during digitization processes.

Hidden information can be used for secrecy, to protect copyright, prevent tampering or add extra information.

Steganography – Modern Techniques

Example 1: Covering data with text.

This book is mostly about cryptography, not steganography.

□	□□□	□	□		□	□□
0	1 0	0	0		0	1

- Single space between words represents binary digit 0.
- Double space between words represents binary digit 1.
- Above hides the 8-bit binary representation of the ! in **ASCII code** (0100001)

Steganography – Modern Techniques

Example 2: Using dictionary.

A	friend	called	a	doctor.
0	10010	0001	0	01001

- Use a dictionary of words organized according to their grammatical usages.
- It assumes a dictionary contain 2 articles, 16 verbs, 32 nouns.
- **Pattern agreed**: article-noun-verb-article-noun.
- Divide the secret binary data into 16-bit chunks.

Bits	Representations
1	First article
2 – 6	First noun
7 – 10	Verb
11	Second article
12 – 16	Second noun

Steganography – Modern Techniques

Example 3: Covering data under colour image.

- Digitized images are made of pixels, with each pixel uses 24 bits (three bytes).
- Each byte represents one of the primary colors (red, green, or blue), hence there are $2^8 = 256$ different shades of each color that is possible.
- In **LSB method**, sets the least significant bit of each byte to zero. Next, hide a binary data in the image by keeping or changing the LSB. Finally, hide the character in three pixels.

Steganography – Drawbacks & Remedy

❖ Drawbacks:

- High overhead to hide relatively few information bits.
- Once the system is discovered, it becomes worthless.

❖ Remedy:

- Insertion method can depend on some sort of key.
- First encrypt the message and then hide using steganography.

Main References for Chapter 1

1. Forouzan, B.A. "***Introduction to Cryptography and Network Security***", Third Edition, McGraw-Hill, 2008.
2. Stallings, W. "***Cryptography and Network Security: Principles and Practices***", Fifth Edition, Pearson Prentice Hall, 2011.

~ THE END 😊 ~